

Contentious Chamber

Decision on the merits 114/2024 of September 6, 2024

File number: DOS-2022-00896

Subject: Recording of working time via biometric data

The Contentious Chamber of the Data Protection Authority, composed of Mr. Hielke Hijmans, president, and Messrs. Dirk Van Der Kelen and Jelle Stassijns, members;

Considering Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), hereinafter "GDPR";

Considering the law of December 3, 2017, establishing the Data Protection Authority, hereinafter "LCA";

Considering the internal regulations as approved by the House of Representatives on December 20, 2018, and published in the Belgian Official Gazette on January 15, 2019;

Considering the documents in the file;

Has made the following decision regarding:

The complainant:

X, represented by Me Gert Buelens, whose office is located at 2800 Mechelen, Nekkerspoelstraat 97, hereinafter "the complainant";

The defendants:

Y1, represented by Me Bernard Dewit, whose office is located at 1050 Brussels, Place Albert Leemans 20, hereinafter "the first defendant";

Y2, represented by Me Jos De Wachter and Me Charlotte Peeters, whose office is located at 3600 Genk, Jaarbeurslaan 19, box 3, hereinafter "the second defendant";

jointly referred to as "the defendants".

Decision on the merits 114/2024 – 2/72

I. Facts and procedure

1.

On February 3, 2022, the complainant filed a complaint with the Data Protection Authority against the first defendant. Initially, this complaint was deemed inadmissible. The complaint was reintroduced and declared admissible on March 29, 2022.

The complainant worked for the first defendant from March 2021 until February 24, 2022, first as a temporary worker and from June 2021 as a permanent employee. On March 16, 2020, the first defendant implemented a time recording system using fingerprints for all staff working at its two sites. According to the first defendant, the system applies to approximately 200 workers, including 44 employees, 74 manual workers, 29 temporary workers, and the rest being "foreign workers." The provider of the system (the second defendant) is a subsidiary of an international group headquartered in Japan, with activities in the United States and China, among others. The complainant believes that the processing of his fingerprints (one from each hand) violates his right to data protection because he did not voluntarily provide these fingerprints and because he was not informed about the data retention conditions or the retention period. Finally, the complainant also expresses concern in his complaint about a potential transfer to a third country that does not provide sufficient guarantees, given the geographical location of the headquarters of the first defendant's parent company.

2.

On March 29, 2022, the complaint was declared admissible by the Frontline Service based on Articles 58 and 60 of the LCA, and the complaint was forwarded to the Contentious Chamber under Article 62, § 1 of the LCA.

3.

On April 21, 2022, in accordance with Article 96, § 1 of the LCA, the request from the Contentious Chamber to conduct an investigation was forwarded to the Inspection Service, along with the complaint and the inventory of documents.

4.

On August 29, 2022, the investigation by the Inspection Service was concluded, the report was attached to the file, and it was forwarded by the general inspector to the president of the Contentious Chamber (Article 91, § 1 and § 2 of the LCA).

The report contains findings related to the subject of the complaint and makes the following findings regarding the first defendant:

1. a violation of Articles 5.1.a), 6.1, and 9.1 of the GDPR;
2. a violation of Article 5.1.b) of the GDPR;
3. no violation of Article 5.1.c) of the GDPR;
4. a violation of Articles 5.1.a) in conjunction with 12.1 and 13 of the GDPR;

Decision on the merits 114/2024 – 3/72

5. a violation of Articles 5.1.a) in conjunction with 12.1 and 15 of the GDPR;
6. a violation of Article 5.2 of the GDPR;
7. a violation of Article 28.3 of the GDPR;
8. a violation of Article 28.1 of the GDPR;
9. a violation of Article 32 of the GDPR;
10. a violation of Article 35 of the GDPR;
11. no indication of potential transfers of biometric data to third countries or international organizations.

The report contains findings related to the subject of the complaint against the second defendant and establishes that it has not fulfilled its obligation under Article 28.3 of the GDPR to conclude a valid subcontracting agreement.

The report also contains findings that exceed the subject of the complaint.

The Inspection Service notes, in broad terms, that it concerns:

1. a violation of Article 30 of the GDPR by the first defendant for failing to maintain a record of processing activities prior to the inspection inquiry and due to the incomplete content of the current record of processing activities;
2. a violation of the obligation to appoint a data protection officer under Article 37.1.b) and c) of the GDPR by the second defendant.

5.

On September 1, 2022, the Litigation Chamber decides, pursuant to Article 95, § 1, 1° and Article 98 of the LCA, that the case may be examined on the merits.

6.

On September 1, 2022, the parties concerned are informed by registered mail of the provisions as set out in Article 95, § 2 as well as Article 98 of the LCA. They are also informed, pursuant to Article 99 of the LCA, of the deadlines for submitting their conclusions.

For the findings related to the subject of the complaint, the deadline for receiving the defendants' responses has been set for October 13, 2022, the deadline for the complainant's reply has been set for November 3, 2022, and finally, the deadline for the defendants' reply has been set for November 24, 2022.

Regarding the findings exceeding the subject of the complaint, the deadline for receiving the second defendant's response has been set for October 13, 2022.

Decision on the merits 114/2024 – 4/72

7.

On September 9, 2022, the second defendant requests a copy of the file (Article 95, § 2, 3° of the LCA), which was transmitted to them on September 13, 2022.

8.

On September 25, 2022, the complainant requests a copy of the file (Article 95, § 25, 3° of the LCA), which was transmitted to them on October 5, 2022.

9.

On September 25, 2022, the complainant agrees to receive all communications related to the case electronically and expresses their intention to exercise the right to be heard, in accordance with Article 98 of the LCA.

10.

On September 28, 2022, the first defendant agrees to receive all communications related to the case electronically and requests a copy of the file (Article 95, § 2, 3° of the LCA), which is sent to them on October 5, 2022, and indicates that they wish to use the opportunity to be heard, in accordance with Article 98 of the LCA.

11.

On October 13, 2022, the Litigation Chamber receives the responses from the first defendant regarding the findings related to the subject of the complaint.

First, the first defendant describes the strained working relationship with the complainant. The findings of the Inspection Service regarding the lawfulness of processing, the principle of transparency, the principle of purpose limitation, and the principle of data minimization are not contested by the first defendant. They claim to have since remedied these violations. However, the first defendant contests the findings related to the complainant's right of access and asserts that they have complied with it in accordance with the GDPR. The first defendant also contests the finding that they did not take sufficient security measures. They engaged an expert in the field and received adequate documentation to ensure the seriousness of the measures taken by the provider (the second defendant).

12.

On October 13, 2022, the Litigation Chamber receives the responses from the second defendant regarding the findings related to the subject of the complaint.

The second defendant claims to be able to share accurate knowledge about the system. They also assert that they timely provided the relevant information to the first defendant. Furthermore, the second defendant argues that they do not process personal data, and therefore not biometric personal data, as the individuals concerned are not identifiable to them, since they only have encrypted files. These responses also include the second defendant's reaction to the findings made by the Inspection Service outside the scope of the complaint. The second defendant asserts that they were not required to appoint a data protection officer under either Article 37.1.b) or Article 37.1.c) of the GDPR. In the meantime, the second defendant has voluntarily appointed a data protection officer.

**\*\*Decision on the Merits 114/2024 – 5/72\*\***

13.

On November 3, 2022, the Litigation Chamber received the reply conclusions from the complainant.

First, the complainant argues that the first defendant's description of the state of the employment relationship between the two parties is not relevant in the context of the present proceedings.

Regarding the findings of the Inspection Service concerning the subject of the complaint, he requests confirmation from the Litigation Chamber.

14.

On November 24, 2022, the Litigation Chamber received the rejoinder conclusions from the first defendant regarding the findings related to the subject of the complaint, in which she reiterates her arguments from the response conclusions.

15.

On November 24, 2022, the Litigation Chamber received the rejoinder conclusions from the second defendant concerning the findings related to the subject of the complaint. The second defendant refers to her response conclusions and further requests the Litigation Chamber to take into account the actual motivations of the parties.

16.

On December 2, 2022, the parties are informed that the hearing will take place on February 17, 2023.

17.

On December 2, 2022, the complainant notifies that he no longer wishes to be heard.

18.

On February 17, 2023, the present parties are heard by the Litigation Chamber.

19.

On February 22, 2023, the minutes of the hearing are submitted to the parties who appeared.

20. On February 28, 2023, the Litigation Chamber receives some remarks from the second defendant regarding the minutes, which it decides to include in its deliberation.

21.

On June 4, 2024, the Litigation Chamber informs the first defendant of its intention to impose an administrative fine as well as the amount of it, in order to give her the opportunity to defend herself before the sanction is actually imposed.

22.

On August 26, 2024, the Litigation Chamber receives the response from the first defendant regarding the intention to impose an administrative fine, as well as the amount of it.

## **\*\*II. Motivation\*\***

### **\*\*II.1.\*\***

Legality of Processing (Art. 5.1, a), 6.1 and 9.2 of the GDPR) Regarding the First Defendant

23.

The question arises as to whether the processing of personal data in the context of time recording by the first defendant constitutes lawful processing.

### **\*\*Decision on the Merits 114/2024 – 6/72\*\***

24.

The basic principle of Article 5.1.a) of the GDPR is that personal data may only be processed lawfully.

#### **\*\*II.1.1.1.\*\***

Categories (Particular) of Personal Data

25.

Under Article 4.1) of the GDPR, personal data means "any information relating to an identified or identifiable natural person (the 'data subject')." An identifiable person is one who can be identified, directly or indirectly, particularly by reference to one or more specific elements, specific to their physical or physiological identity.

26.

According to Article 4.14) of the GDPR, biometric data are personal data resulting from a specific technical processing, related to the physical, physiological, or behavioral characteristics of a natural person, which allow or confirm their unique identification, such as facial images or fingerprint data.

27.

Article 9.1 of the GDPR defines special categories of personal data as follows: "[...] personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, as well as the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, data concerning health, or data concerning a person's sex life or sexual orientation [...]." The parties do not contest that the first defendant acts as the data controller within the meaning of Article 4.7) of the GDPR regarding the time recording of its workers based on their biometric data.

28.

In light of the above, the Litigation Chamber finds that the fingerprint constitutes biometric data within the meaning of Article 4.14) of the GDPR. Since it is used by the first defendant to identify the data subject in the context of time recording, it also constitutes special personal data within the meaning of Article 9.1 of the GDPR concerning the first defendant.

#### **\*\*II.1.1.2.\*\***

Prohibition of Processing Biometric Data

29.

The Litigation Chamber will examine below whether the first defendant has lawfully processed the particular category of personal data in the context of the time recording of its workers.

30. Personal data that are particularly sensitive deserve specific protection because their processing may pose high risks to fundamental freedoms and rights. The processing of specific categories of data

may...

Decision on the merits 114/2024 – 7/72

the processing of personal data is therefore prohibited under Article 9.1 of the GDPR, unless a legal exception applies.<sup>1</sup>

31.

If there is processing of special categories of personal data in accordance with Article 9.1 of the GDPR, the data controller must designate a legal basis in accordance with Article 6 of the GDPR as well as a reason for exception under Article 9.2 of the GDPR for the processing to be considered lawful. This combination of a basis from Articles 6.1 and 9.2 of the GDPR was recently confirmed in the Meta judgment (C-252/21) by the Court of Justice<sup>2</sup>, in which the Court expressly states that the processing of sensitive personal data is only permitted if such processing can be qualified as lawful under Article 6.1 of the GDPR. The Opinion 2/2019 of the European Data Protection Board (EDPB)<sup>3</sup> and the Opinion 06/2014 of the Article 29 Working Party on Data Protection<sup>4</sup> also logically refer to the application of both Article 6 of the GDPR and Article 9 of the GDPR in the case of processing a special category of personal data. Recital 51 of the GDPR clearly indicates that Article 6 of the GDPR must always be applied.

32.

It is the responsibility of the data controller to determine what the appropriate legal basis is in light of the purpose of the processing.<sup>5</sup> Given that different legal bases lead to different consequences, particularly in terms of rights for the data subjects, the data controller is not permitted to rely on one or the other legal basis at will depending on the circumstances. Once a specific legal basis has been chosen, the aim is not to switch from one to another or to revert to another legal basis for the same processing activity, for the same purposes, when the chosen legal basis ceases to apply.<sup>6</sup> Article 5.1.b) of the GDPR indeed requires that personal data "shall be collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes; [...] ('purpose limitation')." When the same processing pursues multiple purposes, each purpose must be based on a legal basis.<sup>7</sup>

33. The question then arises as to which legal basis from Articles 6.1 and 9.2 of the GDPR the first defendant invokes for the disputed processing of a special category of personal data. After investigation, the Inspection Service

1 See Recital 51 of the GDPR.

2 CJEU, Judgment of July 4, 2023, Meta, C-252/21, ECLI:EU:C:2023:537, para. 90.

3 Opinion 3/2019 (EDPB) regarding questions and answers on the interaction between the Clinical Trials Regulation (CTR) and the General Data Protection Regulation (GDPR) (Article 70, paragraph 1, point b)) of January 23, 2019.

4 Opinion 06/2014 (WP 29) on the concept of legitimate interest pursued by the data controller within the meaning of Article 7 of Directive 95/46/EC.

5 See also Decision 74/2023, para. 74, of the Contentious Chamber.

6 See for example Decisions 38/2021, 54/2023, and 77/2023 of the Contentious Chamber.

7 See also Decision 77/2023, para. 77, of the Contentious Chamber.

Decision on the merits 114/2024 – 8/72

results in the finding that the documentation provided does not allow for a clear establishment of the legal basis precisely invoked by the first defendant for the disputed processing. On the one hand, the first defendant indeed invokes different legal bases in different documents, and on the other hand, it does not invoke a single legal basis but several legal bases simultaneously. In any case, the Inspection Service finds that none of the invoked legal bases can constitute a valid legal basis for the disputed processing.

34. The first defendant does not contest the findings of the Inspection Service. In its conclusions, the first defendant states that during the welcome day for new staff members, the human resources manager distributes the welcome brochure and that the worker then gives their consent to the recording of time based on their fingerprints. The first defendant admits that this practice is contrary to the recommendation of the Knowledge Centre of the APD on the processing of biometric data dated

December 1, 2021, according to which, given the subordination in the work context, it is unlikely that the concerned person can refuse their consent to the processing of data without fear of negative consequences arising from that refusal. As a mitigating circumstance, the first defendant argues that when the new work regulation was introduced, no worker commented on the additions regarding the biometric system. It was possible to communicate remarks anonymously. No union delegation made any comments. Furthermore, the workers themselves indicated that they preferred the biometric system to the access badge system.

35. Regarding the lawfulness of the processing, the Contentious Chamber notes that in its response conclusions, the first defendant does not explicitly mention on which legal basis of Article 6.1 in conjunction with Article 9.2 of the GDPR it relies for the disputed processing. The Contentious Chamber also notes that during the investigation, different legal bases were put forward for the disputed processing of personal data. Based on the conclusions and the hearing, the Contentious Chamber finds that the first defendant ultimately invokes consent as the legal basis. The Contentious Chamber will now verify whether the first defendant can legitimately invoke the exception of consent within the meaning of Article 9.2.a) of the GDPR.

36. Article 4.11) of the GDPR defines consent as any manifestation of will, free, specific, informed, and unambiguous, by which the concerned person accepts, by a declaration or by a clear affirmative action, that personal data concerning them be subject to processing.

Decision on the merits 114/2024 – 9/72

37.

For consent to be informed, the data subject must be informed, among other things, of the identity of the data controller, the purpose of the processing, the (types of) data processed, and the existence of the right to withdraw consent.<sup>8</sup>

38. A data subject must also be able to give their consent freely. In the EDPB Guidelines on consent under the GDPR, the following remark is made:

“A power imbalance may also occur in the context of employment relationships. Given the dependency resulting from the employer/employee relationship, it is unlikely that the data subject will be able to refuse to give their consent to their employer regarding the processing of their data without fearing or incurring negative consequences as a result of that refusal. It is thus unlikely that an employee will be able to respond freely to a request for consent from their employer aimed at activating surveillance systems, such as surveillance cameras, in the workplace, or at completing evaluation forms, without feeling obliged to consent. Therefore, the EDPB considers it problematic for employers to process the personal data of their current or potential employees based on their consent, as it is unlikely that such consent is given freely. For the majority of these data processing activities at work, the legal basis cannot and should not be the consent of employees (Article 6(1)(a)) due to the nature of the employer/employee relationship. However, this does not mean that employers can never rely on consent as a legal basis for data processing. There may be situations where the employer can demonstrate that consent is, in fact, given freely. Given the power imbalance between an employer and their staff, employees can only give their consent freely in exceptional situations, when absolutely no negative consequences will result from their refusal to give consent [...] Power imbalances are not limited to public authorities and employers; they can also occur in other situations. As highlighted by the G29 in several opinions, consent can only be valid if the data subject is truly able to exercise a choice and if there is no risk of deception, intimidation, coercion, or significant negative consequences (e.g., significant additional costs) if they do not give their consent. Consent will not be free when any element of constraint, pressure, or inability to exercise a genuine choice is present.”

<sup>8</sup> See Recital 42 of the GDPR, the Guidelines on consent under Regulation 2016/679 of November 28, 2017, p. 15, and Article 7, § 3 of the GDPR.

Decision on the merits 114/2024 – 10/72

39. In light of these elements, the Dispute Chamber emphasizes that in an employment relationship, processing can only be based on consent in exceptional circumstances. It examines to what extent such a circumstance is present in this case.

40. Under Article 7.1 of the GDPR, the data controller must be able to demonstrate that the data

subject has given their consent to the processing of personal data concerning them.

41. The conditions of Article 7 of the GDPR also apply to the notion of consent referred to in Article 9.2 of the GDPR. To meet the condition of Article 9.2.a) of the GDPR for an exception to the prohibition on processing biometric data under Article 9.1 of the GDPR - in addition to the conditions defined in Article 7 of the GDPR for consent - the data subject must give explicit consent. In other words, inferring consent from the fact that a person does not act or protest is not permitted.

42. In its response dated August 5, 2022, the first defendant confirmed to the Inspection Service that previous versions of the work regulations prior to the June 2022 version did not contain any provisions regarding a biometric time recording system. Therefore, there is no question of informed consent.

43. The first defendant submits to the Dispute Chamber the welcome brochure that was provided to new employees upon their initial hiring, as well as the work regulations. These documents serve to inform the worker about the time recording system. These documents were signed, but for acknowledgment and not for agreement. Although these documents provide some - albeit brief - information to workers about the time recording system, it cannot be concluded on this basis that there is unequivocal consent.

44. Furthermore, the first defendant has not demonstrated that the consent was given freely. The welcome brochure states the following: "[your] salary is based on your time records, so be sure not to forget it." [Note: the excerpts from the file are free translations made by the Translation Service of the Data Protection Authority, in the absence of an official translation]. Moreover, Article 32 of the work regulations indicates that failure to comply with the time recording rules may result in sanctions. Based on the inspection report, the Dispute Chamber finds that recording time by fingerprint is the only time recording method in effect. This means that if a data subject refused to give their consent to time recording by fingerprint, they would be subject to the sanctions provided for in the work regulations, given that no other method is available.

9 Guidelines 2016/679 of the EDPB on consent under Regulation 2016/679 of November 28, 2017, p. 23.

Decision on the merits 114/2024 – 11/72

provided for the recording of time. On the contrary, the work regulations even stipulate that all staff members are required to record their working time via Z, and that there is no other system for recording working time, such that there is no freedom of choice for workers. Consequently, negative consequences are associated with the worker's refusal to give their consent. The Disciplinary Chamber also notes that the complainant was initially employed as a temporary worker, which places them in an even more unfavorable position to make remarks regarding the time recording system.

45. The first defendant believes that the workers have given their consent for the use of their fingerprints and that no one has ever opposed it. The first defendant states that the badge system was perceived as impractical by the workers and that it had only good intentions. Furthermore, the first defendant argues that the workers could also express their desire for another method of time recording. Therefore, the first defendant believes that the workers were able to freely give their consent.

46. The Disciplinary Chamber does not follow this reasoning. Given the dependency resulting from the relationship between the employer and the worker, it is unlikely that the worker can freely give their consent. The Disciplinary Chamber refers in this context to the EDPB guidelines on consent, according to which there may be an imbalance of power in a work context. Since this case involves an employer/worker relationship, it is improbable that the individual concerned, as a worker, could refuse to give their consent without fear or without a real risk of harmful consequences. The Disciplinary Chamber also observes that neither the welcome brochure nor the work regulations at the time the complainant was employed mentioned that other methods of time recording could be requested. However, during the hearing, the first defendant produced documents showing that the disputed time recording system was abandoned following the findings of the Inspection Service.

47. Based on the following facts, the Disciplinary Chamber concludes that the first defendant has not demonstrated that its workers have given their explicit consent to the processing of their biometric data. Specific, informed, and unambiguous consent has therefore not been established.

48. The Disciplinary Chamber thus concludes that in the present case, the first defendant has violated the fundamental prohibition on processing special categories of personal data, as it cannot invoke Article 6.1.a) in conjunction with Article 9.2.a)

10 [https://www.edpb.europa.eu/sites/default/files/files/file1/edpb\\_guidelines\\_202005\\_consent\\_fr.pdf](https://www.edpb.europa.eu/sites/default/files/files/file1/edpb_guidelines_202005_consent_fr.pdf).  
Decision on the merits 114/2024 – 12/72

of the GDPR regarding the disputed processing of special categories of personal data, namely time recording based on biometric data. There is therefore a question of a violation of Article 9.1 in conjunction with Article 6.1.a) and Article 9.2.a) of the GDPR. The fact that the disputed processing was terminated following the findings of the Inspection Service does not prevent the acknowledgment of the historical violation.

II.2. Principle of purpose limitation (Article 5.1.b) of the GDPR) concerning the first defendant

49. To the extent necessary, the Contentious Chamber recalls that personal data may only be collected and processed for specified, explicit, and legitimate purposes. When data is subsequently used for another purpose, this new purpose must be compatible with the initial purpose of collection. The principle of purpose limitation thus comprises two elements:

- a. personal data must be processed for specified, explicit, and legitimate purposes; and
- b. when personal data is collected, it may not be processed subsequently in a manner incompatible with those purposes.

Thus, the principle of purpose limitation ensures that limits are set on the use of personal data, taking into account the reasonable expectations of the data subjects and the fact that subsequent use for purposes other than those for which the data was initially collected may also prove useful.

50. During the inspection investigation, the first defendant referred to four purposes:

- the recording of working time allowing for the establishment of payroll records;
- the prevention of fraud during time recording;
- security reasons, notably to know at all times how many people are present on the production site in case of fire or for the control of successive shift changes; and
- the control of access to the employer's building.

51. The Inspection Service observes that the fourth purpose (control of access to the building) does not appear in any other document and that it emerges from the letter of the first defendant that processing for this purpose had not yet been carried out. This is therefore a potential subsequent processing whose purpose, in the sense of Article 5.1.b) and Article 6.4 of the GDPR, cannot be incompatible with the initial purposes. The Inspection Service concludes that processing for access control will only be possible in very limited cases, given that these are biometric data, and emphasizes that the initial collection was already unlawful. The Inspection Service refers to the work regulations (June 2022 version) which mention in two places the same three purposes as in the response of the first defendant: time recording (including payroll management), combating fraud, and security. However, the record of processing activities mentions only one purpose, namely time recording. In the welcome brochure, the Inspection Service finds two purposes, namely time recording and security reasons. The Inspection Service objects that the purpose of combating fraud does not appear in the welcome brochure. This is important for the Inspection Service because it is the only document through which the first defendant can demonstrate that it was brought to the complainant's attention prior to processing. The Inspection Service therefore finds that the condition of collection for "specified, explicit, and legitimate purposes" is not fulfilled.

52. Finally, the Inspection Service concludes that none of the purposes fulfill the legitimacy condition set out in Article 5.1.b) of the GDPR. Given that the initial processing was unlawful, any purpose for which the data is collected is unlawful. Consequently, the inspection report indicates that in all cases, the purposes cited by the first defendant are not legitimate and that in some cases, they are also not determined or explicit.

53. The first defendant argues that it has taken this conclusion into account and intends to comply with it. It has therefore immediately suspended all future projects related to the biometric security of its



company's site.

54. The Contentious Chamber subsequently verifies whether the principle of purpose limitation is respected.

A specified purpose

55. As already indicated, a purpose must be specified, which means that the purpose of processing must be determined before obtaining the data. In accordance with Article 13.1 of the GDPR, when personal data is collected from the data subject, the data controller must inform them of the purpose of the processing at the time of data collection. Therefore, only the two purposes "time recording" and "security of the company's site" meet this condition, as they were communicated to the complainant in the welcome brochure.

A specified and explicit purpose

56. The explanation of purposes can be done in various ways, for example, by describing the purposes in a notification to the data subjects.

Decision on the merits 114/2024 – 14/72

declares that the communication of purposes in the welcome brochure may meet this condition. Furthermore, the Contentious Chamber asserts that the average citizen can understand what the purposes "time recording" and "site security of the company" entail.

A legitimate purpose

57.

Personal data must be obtained or collected for legitimate purposes. For the purposes to be legitimate, the processing must - at all its stages and at all times - be based on at least one of the legal bases cited in Article 6 of the GDPR. Given that it has already been established in point II.1 that the processing is not legitimate, there is also no question of a legitimate purpose.

58. In light of the above, the Contentious Chamber finds that there is a violation of Article 5.1.b) of the GDPR.

II.3. Data minimization principle (Article 5.1.c) of the GDPR) regarding the first defendant

59.

According to the data minimization principle as defined in Article 5.1.c) of the GDPR, the personal data processed must be adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed. It follows that personal data can only be processed if the purpose of the processing cannot be reasonably achieved by other means. The processing must be proportional to the intended purpose.

60. The Inspection Service notes that the first defendant cannot produce any internal documents or evidence of deliberation or decision-making processes demonstrating the implementation of a proportionality test. The Inspection Service therefore concludes that the first defendant did not examine whether the pursued purpose could not have been reasonably achieved by other means, such as multi-factor authentication.

61.

Regarding the purpose of "combating fraud," the Inspection Service finds that the time recording system is not proportionate to the case of fraud that led to the introduction of the disputed system. This incident involved a worker who left work early and improperly signed the paper attendance register for the end of the day. The Inspection Service believes that a less intrusive control system would have also been sufficient to detect and prevent such fraud.

62.

Regarding the purpose of "staff safety," namely ensuring that machines are systematically checked by a worker, the Inspection Service does not see a clear link between this purpose and the means (the disputed time recording), given that the

13 [https://ec.europa.eu/justice/article-29/documentation/opinion-recommendation/files/2013/wp203\\_en.pdf](https://ec.europa.eu/justice/article-29/documentation/opinion-recommendation/files/2013/wp203_en.pdf), p. 19

Decision on the Merits 114/2024 – 15/72

The presence of a worker on the company's site does not equate to the systematic control of a

particular machine, especially since clocking out for breaks is not required, according to the welcome brochure. In the sense that fire safety must also be included in the purpose of "staff safety," the Inspection Service understands, however, the importance of a correct attendance register. The Inspection Service emphasizes, however, that what matters most during an evacuation is knowing how many people are present in the building and, secondarily, their identity.

63. In its conclusions, the first defendant commits to immediately ending the time recording system based on biometric data. The first defendant explains that its clients are very demanding regarding safety, which requires it to obtain a whole series of certifications to which many safety conditions apply. In this regard, it submits two documents. It argues that the environment in which it must operate is very restrictive and that this has led it to work with the disputed time recording system.

64. The Disciplinary Chamber recalls that when assessing the necessity of using sensitive personal data, such as biometric data, to maintain work time records, it is appropriate to examine the available means that allow achieving the same purpose in a less intrusive manner for the workers' privacy. It may be assumed that employers can have numerous means allowing workers to log in and out of a remuneration system that is not based on biometric data or other sensitive personal data. For example, time clocks, employee cards, and access codes. Furthermore, the aforementioned means can be combined with spot checks or a monitoring body when accessing the workplace. The Disciplinary Chamber understands that the first defendant must meet the high demands of its clients, but at the same time believes that the processing of particular personal data is not necessary to achieve the purposes of the first defendant—namely, time recording, fraud prevention, or staff safety—and that these purposes can be achieved through other less burdensome measures that do not require the systematic processing of workers' biometric data.

65. The Disciplinary Chamber emphasizes that the use of biometric data for the unique identification of a person is generally subject to very strict limitations. This is particularly relevant when other less strict measures are insufficient and may be relevant when the processing is intended for controlling access to certain areas of the workplace due to specific security considerations, such as the handling of foodstuffs or hazardous substances.

Decision on the merits 114/2024 – 16/72

(article 9.2.g) of the GDPR). Such circumstances are not present in this case.

The Contentious Chamber concludes that there is a violation of Article 5.1.c) of the GDPR.

II.4. Principle of data retention limitation (Article 5.1.e) of the GDPR) regarding the first defendant

66. In accordance with Article 5.1.e) of the GDPR, "personal data must be kept in a form which permits identification of the data subjects for no longer than is necessary for the purposes for which the personal data are processed." In practical terms, this means that once the purpose of the processing has been achieved, or when the legal basis is no longer valid (for example, due to the withdrawal of consent by the data subjects or the disappearance of a significant public interest), the biometric data in question must be deleted. However, this does not preclude the data from being retained for a longer period under a legal obligation or when such data are necessary for a judicial procedure.

67. The Knowledge Center of the DPA emphasizes that raw biometric data collected during the first phase of data collection of a biometric system (registration phase) must, in principle, be deleted immediately once the biometric template has been created. Furthermore, the data collected during the second phase of data collection may not be retained longer than necessary to compare the collected data with the reference information.<sup>14</sup>

68. Regarding the principle of data retention limitation, the Inspection Service does not receive any reference to the retention period of the first defendant. The Inspection Service deduces from Annex 10 of the working regulations (June 2022 version) and the record of processing activities that the data are retained for the entire duration of the employment relationship. However, these documents do not establish any distinction between raw biometric data and the resulting biometric templates. Based on its investigation, the Inspection Service concludes that the retention periods for raw biometric data appear to comply with the principles set forth by the Knowledge Center of the DPA. The Inspection Service states that a thorough investigation is not proportionate since the processing in question has already proven to be unlawful on several points.

69. The Contentious Chamber notes that the Inspection Service did not find any violation in this regard and sees no reason to adopt a different viewpoint. The Contentious Chamber therefore concludes that there is no violation of Article 5.1.e) of the GDPR.

14 Recommendation 01/2021 on the processing of biometric data, p. 35, available via the following link:

<https://www.autoriteprotectiondonnees.be/publications/recommandation-01-2021-du-1-decembre-2021.pdf>.

Decision on the merits 114/2024 – 17/72

II.5. Information obligations (Article 5.1.a) in conjunction with Articles 12.1 and 13 of the GDPR) regarding the first defendant

70. During its investigation, the Inspection Service finds that the information obligations set out in Article 12.1 and Article 13 of the GDPR, which require that information be provided to data subjects at the time when personal data is collected, have not been complied with.

71.

Based on Articles 12.1, 13.1, and 13.2 of the GDPR, it is necessary for the first defendant, as the data controller, to provide data subjects with concise, transparent, and understandable information about the personal data being processed. The aforementioned transparency obligations are a realization of the general obligation of transparency set out in Article 5.1.a) of the GDPR. The Contentious Chamber will examine whether the first defendant has fulfilled its information obligations.

72.

The Contentious Chamber reads in the inspection report that the Inspection Service concludes that there has been a violation of Articles 12.1 and 13 of the GDPR, given that the welcome brochure, the only document containing information about the disputed processing that was provided to the complainant upon their entry into service, did not contain all the information required by the GDPR. Article 13 of the GDPR defines the information that the data controller must provide to the data subject when personal data is collected directly from that person, and this must occur at the time of obtaining that data. The only information intended for data subjects that the Inspection Service can deduce from the welcome brochure is as follows: the category of personal data processed, one of the explicit purposes of time recording (namely, time recording by fingerprint), and an implicit purpose (namely, personnel security). When questioned a second time on this matter, the first defendant did not provide any new elements.

73.

According to the findings of the Inspection Service, the work regulations (2020 version), which were provided to the complainant upon their entry into service, only refer to the use of "electronic recording devices" for measuring and controlling work and contain only the following reference to the right to data protection:

"The law of December 8, 1992, relating to the protection of privacy and/or the General Data Protection Regulation (GDPR) will be respected when processing personal data."

74.

According to the Inspection Service, the above information did not meet the information obligations under Articles 12.1 and 12.3 of the GDPR. In its conclusions, the first defendant argues that from the opening of the inspection investigation, it has

Decision on the Merits 114/2024 – 18/72

immediately took the measure of the obligations it had to comply with. It then began to adapt its working rules and will continue to correct them.

75.

The Disciplinary Chamber will examine whether the information obligations are fulfilled under Article 13 of the GDPR in conjunction with Article 12.1 of the GDPR. After reviewing the conclusions of the first defendant and the related documents, the Disciplinary Chamber finds that the first defendant has indeed taken measures in this regard. This is evident from the fact that it attached a modified work regulation from 2022 to its conclusions. In light of the inspection report, the Disciplinary Chamber notes that at the time of the complainant's employment, the welcome brochure was the only source of

information for workers until the work regulation was modified in June 2022 (hereinafter, the "work regulation (2022 version)"). The Disciplinary Chamber will therefore first examine the welcome brochure as it applied at the time of the complainant's employment and then the work regulation (2022 version), particularly in relation to the disputed time recording system.

#### Welcome Brochure

76.

The welcome brochure provides the following information regarding the disputed processing: "We use a time recording system based on fingerprints. After the welcome session, you will be registered and you must clock in at the beginning and at the end of your shift. We have a short team change, which means you must clock in at least 5 minutes in advance. Your salary is based on these clock-ins, make sure not to forget it. During your break, you do not need to clock in at the beginning or at the end, unless you leave the site, this for safety reasons."

77.

Regarding the mention of the identity of the data controller in the welcome brochure, the Disciplinary Chamber finds that the identity of the first defendant as the employer is implicitly put forward as that of the data controller, although the Disciplinary Chamber emphasizes that it is recommended to mention it explicitly. The Disciplinary Chamber further notes that the welcome brochure does not meet other information obligations. In particular, regarding retention periods (Article 13.2.e of the GDPR), purposes, and legal basis (Article 13.1.c of the GDPR), the Disciplinary Chamber finds that these are not (sufficiently) included in the welcome brochure. Given that the first defendant unlawfully invokes consent based on Article 6.1.a) and Article 9.2.a) of the GDPR, it was also necessary to inform the data subjects that they had the right to withdraw their consent (Article 13.2.c) of the GDPR). As for the mention of the possibility to file a complaint with the Data Protection Authority (Article 13.2.d) of the GDPR), the Disciplinary Chamber finds that this is also not mentioned in the welcome brochure.

#### Decision on the Merits 114/2024 – 19/72

78.

In light of the above, the Disciplinary Chamber concludes that the welcome brochure does not satisfy the information obligations prescribed by Article 13 of the LCA and that the information contained in the welcome brochure is not presented transparently and understandably as required by Article 12.1 of the LCA.

#### Work Regulation (2022 Version)

79.

The first defendant claims to have already taken measures to comply with its information obligations by adapting the work regulation. The Disciplinary Chamber notes that the work regulation (2022 version) includes an annex 10 titled "GDPR and Privacy Policy for Employees."

80. In the work regulation (2022 version), the Disciplinary Chamber notes the following regarding the information obligations related to the processing of biometric data.

81.

Regarding the purposes and legal basis of the processing (Article 13.1.c of the GDPR), the Disciplinary Chamber finds that the work regulation (2022 version) states that biometric data and information related to time recording via fingerprints are processed based on Article 6.1.f) of the GDPR, namely "the processing is necessary for the purposes of the legitimate interests pursued by [the first defendant], which include (i) the protection of the company through reliable time recording, (ii) ensuring the safety of personnel, (iii) controlling and facilitating access to the company's premises." Regarding the legality of the basis for processing and the applicable legal basis, the Disciplinary Chamber refers to point II.1. Furthermore, the Disciplinary Chamber finds that the work regulation (2022 version) meets the information obligations under Article 13 of the GDPR. The information is also presented schematically, making it accessible in a concise, transparent, and understandable manner for the data subject (Article 12.1 of the GDPR).

82.

Based on the above, the Disciplinary Chamber finds that the first defendant has committed a violation of Article 12.1 of the GDPR in conjunction with Articles 13.1.c), 13.2.c), d), and e) of the GDPR due to

the lack of transparency in the welcome brochure, and of Article 12.1 of the GDPR in conjunction with Article 3.1.c) of the GDPR regarding the work regulation (2022 version) from the implementation of the disputed time recording system until its cessation in December 2022. The fact that the violations of Articles 13.2.c), d), and e) have been resolved does not prevent the Disciplinary Chamber from noting a historical violation.

Decision on the Merits 114/2024 – 20/72

II.6. Article 12.1 and Article 15 of the GDPR (right of access) regarding the first defendant

Findings in the Inspection Report

83. In the inspection report, the Inspection Service concludes that there is a violation of Article 5.1.a) in conjunction with Article 12.1 and Article 15 of the GDPR concerning the right of access. The Inspection Service notes that the complainant exercised his right of access twice in writing. The first time by email on February 21, 2022, and the second time by registered mail on March 31, 2022. During the inspection inquiry, the first defendant claims to have responded orally to the first request during a meeting with the union representative on March 15, 2022. The Inspection Service can deduce from the email exchanges between the union secretary and the first defendant, with the complainant in copy, that the requested information was part of the agenda of this meeting and that the initiative for the meeting came from the complainant through his union representative. Given that the initiative came (indirectly) from the complainant, the Inspection Service considers it possible, under the final part of Article 12.1 of the GDPR, that the first defendant could legally respond to the request orally.

Considering the representation competence of the union delegation established in Belgium by interprofessional collective labor agreement and the prior communication through the relevant union secretary, the Inspection Service believes that the first defendant was reasonably entitled to assume that the access request could be satisfied orally through the union secretary. The Inspection Service therefore concludes that the first defendant makes plausible the fact of having responded to the first access request dated February 21, 2022, within the timeframe provided for in Article 12.3 of the GDPR.

84. In the second access request dated March 31, 2022, the complainant reiterates his initial request and again seeks a written response from the first defendant. This response follows by registered mail on April 20, 2022. The Inspection Service argues that some of the complainant's questions concerned information elements listed in Article 13 of the GDPR and not in Article 15 of the GDPR. Since the first defendant did not comply with the information obligation arising from Article 13 of the GDPR (at the time of exercising the right of access), the Inspection Service concludes that the first defendant should also respond to these questions. According to the Inspection Service, the response from the first defendant is incomplete on the following points:

- Only 2 of the 3 purposes are mentioned. The purpose of combating fraud is not mentioned (Article 15.1.a) of the GDPR).

15 See Collective Labor Agreement No. 5/1. 5.10.2022 Collective labor agreement No. 5 of May 24, 1971, concerning the status of union delegations of personnel in companies, amended and supplemented by collective labor agreement No. 5 bis of June 30, 1971, No. 5 of December 21, 1978, and No. 5 quater of October 5, 2011.

Decision on the Merits 114/2024 – 21/72

- The complainant asked whether he could refuse to give his consent to the processing and also stated that he had never voluntarily given such consent. In its response, the first defendant does not address this question but merely mentions that, according to it, consent was validly given and that the data has since been deleted (since the departure of the complainant). If, according to the first defendant, consent constituted the applicable legal basis for processing, it should have drawn the complainant's attention to the fact that this consent could always be withdrawn, in accordance with Article 13.2.c) of the GDPR.

- If, according to the first defendant, consent did not constitute the applicable legal basis, it should have specified in its response on what legal basis the processing was based, under Article 13.1.c) of the GDPR.

- Depending on the communicated legal basis (as explained above, the first defendant simultaneously

invokes different legal bases), it should then have communicated the legitimate interests on which the processing was based (Article 13.1.d) of the GDPR) and the fact that the complainant had the right to object to the processing (Article 15.1.e) of the GDPR) or - if the first defendant invokes a legal obligation - that a refusal or objection was not possible since the processing was necessary for compliance with a legal obligation of the first defendant.

85. The Inspection Service notes that the obligation on the part of the first defendant to respond completely and accurately to the access request persisted despite the fact that between the complainant's initial request dated February 21, 2022, and the response dated April 20, 2022, the processing was interrupted (due to the departure of the complainant). The Inspection Service could not determine what additional or different information may have been communicated verbally by the union secretary during the meeting on March 15, 2022.

#### Position of the First Defendant

86. In its conclusions, the first defendant reiterates the access request of February 21, 2022. The first defendant deduces the following questions from the complainant:

- (i) The policy regarding individuals having access to the "admin" section of the time clock;
- (ii) The possibility of refusing the use of the biometric system;
- (iii) The disappearance of this administrative access and the person responsible for decommissioning it;
- (iv) The retention period and the methods of retention; and
- (v) The security of personal data.

#### Decision on the Merits 114/2024 – 22/72

87.

According to the first defendant, the first two questions were no longer relevant at the time of the second letter dated March 31, 2022, as the complainant had been dismissed on February 24, 2022. However, question (i) was subject to oral and written responses. Regarding question (ii), the first defendant argues that it has not been demonstrated that the complainant would not have had the right to choose another time recording system, given that the complainant was dismissed on February 24, 2022. The complainant is the only worker who complained about not consenting to the taking of his fingerprints. Therefore, it cannot be assumed that the first defendant would have refused such an alternative if the complainant had remained on the employee list. In this regard, the first defendant points out that no other worker made any remarks about the biometric system at the time of its introduction in the new work regulations (2022 version).

88. Regarding question (iii), the first defendant confirms that it was orally stated - during the meeting on March 15, 2022, with the union representative - that the complainant was not at risk. The first defendant indeed no longer had the complainant's biometric data. This was also confirmed in writing.

89. Question (iv) was, according to the first defendant, no longer relevant since the data had already been deleted from the system at the time of the response to the right of access. The first defendant emphasizes that the complainant was dismissed three days after exercising his right of access. At the same time, and since February 3, 2022, he has been represented by the union delegate who confirms a meeting on March 15, 2022, to discuss, among other things, these specific issues. Question (v) was also no longer relevant, according to the first defendant. Since his personal data had already been deleted, the complainant was no longer at risk in this regard.

90. The first defendant concludes that it cannot be criticized for not responding to the complainant's requests dated February 21, 2022, and March 31, 2022, as the exercise of this right no longer had a legitimate interest. Indeed, the complainant's personal data has been deleted, and he knew or should have reasonably known this in light of the meeting on March 15, 2022.

#### Assessment by the Disciplinary Chamber

91. According to the inspection report, the Disciplinary Chamber finds that the complainant exercised his right of access for the first time on February 21, 2022. The file contains email correspondence from which the Disciplinary Chamber can deduce, based on the findings of the Inspection Service, that a consultation took place on March 15, 2022, during which a response was provided to the complainant's questions. However, the complainant himself was not present during these discussions but was represented by the union delegate, which is also stated by the union delegate himself. In his

Decision on the merits 114/2024 – 23/72

Guidelines 01/2022 on the rights of data subjects - right of access<sup>16</sup>, the European Data Protection Board (hereinafter: "EDPB") indicates that the right of access is generally exercised by the data subject themselves, but it is not excluded that a third party may submit the request on behalf of the data subject. Given that such a power of representation is not governed by the GDPR, it is appropriate - as also noted by the Inspection Service - to turn to the applicable national rules, in this case the applicable Belgian collective labor agreements, as explained by the Inspection Service in the inspection report. These rules allow the union representative to represent the complainant when exercising the right of access. In view of the emails dated February 28, 2022, and March 2, 2022, sent by the union representative to the first defendant, the latter could legitimately assume that the former would represent the complainant during the meeting on March 15, 2022. During this meeting, the time recording system via biometric data was also to be discussed. Indeed, the email from the union representative dated February 28, 2022, indicates that the complainant wishes for more clarity regarding their rights as a worker and the functioning of the biometric system.

92.

Still in the aforementioned Guidelines 1/2022, the EDPB addresses how access to personal data should be granted. This should primarily be done by means of a copy of the data, but other modalities, such as verbal information, may suffice if the data subject requests it. Given that the proposal for a meeting came from the union representative, the first defendant can legally communicate the requested information orally and thus respond lawfully to the access request.

93. In light of the above, the first defendant could lawfully assume that the union representative, as the representative of the complainant, would communicate the information provided by the first defendant during the meeting on March 15, 2022, to the complainant.

94. Considering the above and in accordance with the conclusions of the Inspection Service, the Dispute Chamber concludes that the first defendant lawfully responded to the complainant's right of access, according to the modalities requested by the complainant's representative.

95. The Dispute Chamber draws attention to the fact that the aforementioned meeting between the first defendant and the complainant's representative took place on March 15, 2022.

96. On March 31, 2022, the complainant exercised their right of access a second time. The complainant stated that the first defendant had not responded substantively to their email of

16 EDPB,

Guidelines 01/2022 on the rights of data subjects — Right of access 2.0., March 17, 2023, available at [https://www.edpb.europa.eu/system/files/2023-04/edpb\\_guidelines\\_202201\\_data\\_subject\\_rights\\_access\\_v2\\_fr.pdf](https://www.edpb.europa.eu/system/files/2023-04/edpb_guidelines_202201_data_subject_rights_access_v2_fr.pdf).

At the time of the complainant's access request, the first version applied, available at [https://www.edpb.europa.eu/system/files/2022-01/edpb\\_guidelines\\_012022\\_right-of-access\\_0.pdf](https://www.edpb.europa.eu/system/files/2022-01/edpb_guidelines_012022_right-of-access_0.pdf).

Decision on the merits 114/2024 – 24/72

February 21, 2022. This lack of response prompted the complainant to file the present complaint with the APD.

97. The Contentious Chamber recalls that the right of access is not absolute. Article 12.5 of the GDPR provides that when requests from a data subject are manifestly unfounded or excessive, particularly due to their repetitive nature, the data controller may require the payment of reasonable fees or refuse to comply with such requests. As also stated in Recital 63 of the GDPR, the data subject may exercise their right of access easily and at reasonable intervals. The EDPB identifies four criteria that allow a data controller to determine whether the exercise of the right of access is excessive:

- (i) The frequency with which the personal data is modified;
- (ii) The nature of the personal data;
- (iii) The purpose of the processing, including whether the processing has negative consequences for the complainant;
- (iv) Whether successive requests concern the same requested information or the same processing, or different information or processing.

98. By applying the above criteria to the aforementioned case, the Contentious Chamber reaches the

following conclusions. Regarding the first criterion, the Contentious Chamber notes that biometric data is specific to the data subject and therefore is not modified. Similarly, the recorded clock-in times based on fingerprints no longer change and are not supplemented, given the complainant's dismissal on February 24, 2022. The nature of the personal data, which is biometric data, is rather sensitive, which may reduce the duration of the aforementioned "reasonable period." The purpose of the processing, that is to say the third criterion, is the security of personnel, the recording of time for the calculation of wages, and the prevention of clocking fraud, although this purpose is not always mentioned by the first defendant. In itself, these purposes are not likely to have a negative impact on the data subject. Furthermore, the request of March 31, 2022, concerns the same information as that provided on March 15, 2022, following the exercise of the right of access by the complainant on February 21, 2022.

99. The Contentious Chamber observes that the Inspection Service argued that the complainant's dismissal on February 24, 2022, does not prevent the first defendant from responding comprehensively and correctly to the access request. The Contentious Chamber recalls that the data controller must indeed respond comprehensively; however, if the complainant's request was limited to a processing

Decision on the Merits 114/2024 – 25/72

specific, the information provided by the data controller could also be limited to this specific processing.<sup>17</sup> Given that the complainant, through the union representative in their capacity as the complainant's representative, limited their request to the time recording system via biometric personal data and related aspects such as the retention period and the security of this personal data, the Dispute Chamber considers that the information provided by the data controller can be limited to this specific processing.

100. Regarding the position of the first defendant that they no longer had to respond to questions 4 and 5 of the complainant because the personal data had already been deleted, the Dispute Chamber recalls that the right of access is the "gateway" that allows the exercise of other rights conferred by the GDPR to the data subject, such as the right to rectification, the right to erasure, and the right to restriction of processing<sup>18</sup>. The reasoning that certain information no longer needs to be communicated for the past, for example because the data has been deleted, cannot be followed. This would indeed hinder the effective exercise of these rights.<sup>19</sup> Given that the personal data was deleted shortly before the dismissal and that the fingerprint time recording system was still in place at the time of the access requests, the Dispute Chamber considers that the first defendant should not have made disproportionate efforts to respond to questions 4 and 5 of the second access request. Furthermore, the Dispute Chamber also emphasizes that while Article 15 of the GDPR does not provide that information on security measures must be provided as part of an access request, this does not mean that, consequently, no action should be taken regarding the right of access. Indeed, the first defendant could provide information on security measures to the complainant in a more general manner.

101. In light of the above, the Dispute Chamber finds that the first defendant lawfully executed the complainant's access request regarding the first access request dated February 21, 2022, and questions 1 to 3 of the second access request dated March 31, 2022. However, the Dispute Chamber finds that the first defendant did not provide a satisfactory response to questions 4 and 5 of the

17 EDPB, Guidelines 01/2022 on the Rights of Data Subjects — Right of Access, January 18, 2022, para. 35. Available via the following link: [https://www.edpb.europa.eu/system/files/2024-04/edpb\\_guidelines\\_202201\\_data\\_subject\\_rights\\_access\\_v2\\_fr.pdf](https://www.edpb.europa.eu/system/files/2024-04/edpb_guidelines_202201_data_subject_rights_access_v2_fr.pdf).

18 See the most recent ruling of the CJEU, January 12, 2023, Österreichische Post AG-, C-154/21, ECLI:EU:C:2023:3, para. 38, as well as CJEU, July 17, 2014, -YS et al., C-141/12 -and C-372/12, EU:C:2014:2081, para. 44, and CJEU December 20, 2017, -Nowak, C-434/16, EU:C:2017:994, para. 57, see also decision 15/2021 of February 9, 2021, para. 141, and decision 41/2020 of July 29, 2020, para. 47.

19 CJEU of May 9, 2009, Rijkeboer, C-553/07, ECLI:EU:C:2009:293, para. 54.

Decision on the merits 114/2024 – 26/72

second request for access dated March 31, 2022, which results in a violation of



Article 12.1 in conjunction with Article 15.1(d) of the GDPR.

II.7. Article 28.1 of the GDPR regarding the first defendant

102. In accordance with Article 28.1 and Recital 81 of the GDPR, the first defendant has, as the data controller, the obligation to "only engage subprocessors who provide sufficient guarantees regarding the implementation of appropriate technical and organizational measures."

103. The Inspection Service finds that the first defendant has not fulfilled its required due diligence obligation to assess the adequacy of the technical and organizational measures taken by the second defendant. The Inspection Service notes that the first defendant only received the sales brochure for the time recording system from the second defendant during the pre-contractual phase. However, in this document, technical information related to security is scarce and does not add anything to the brief information included in the subcontracting agreement. According to the inspection report, the only element that was not included in the subcontracting agreement but is mentioned in the brochure is the clarification that when data is sent from the terminal to the server, the encryption complies with the HTTPS protocol.

104. Following the first letter from the Inspection Service to the first defendant, the latter requested additional information from the second defendant to demonstrate that the level of security applied was sufficient. The Inspection Service points out that this documentation should have been requested prior to processing and not at the time of announcing an inspection by the Inspection Service. The Inspection Service emphasizes that both the first and second defendants confirm that such an exchange of documentation did not occur earlier. Therefore, the Inspection Service concludes that the first defendant cannot demonstrate that it has effectively verified the guarantees provided by the subprocessor regarding the technical and organizational measures appropriate to the risks associated with the disputed processing of biometric personal data, which constitutes a violation of Article 28.1 of the GDPR.

II.7.1. Position of the first defendant

105. The first defendant contests the finding that it did not take sufficient security measures. It engaged an expert in the field and received sufficient documentation to ensure the seriousness of the second defendant as a supplier. It argues that inadvertently, an annex to the subcontracting agreement was not communicated. This annex is part of the subcontracting agreement.

Decision on the Merits 114/2024 – 27/72

concluded between the parties and contains very specific guarantees regarding the security of processing. Therefore, the content of the subcontracting agreement is not limited to a mere description of the general security measures of the second defendant, but actually contains a detailed description of what is effectively implemented. The categories of data are displayed in the application based on the information previously provided to the Inspection Service. The first defendant indeed made a choice among the various options offered by the second defendant. Thus, there is no question of a violation of Article 28, paragraph 1 of the GDPR.

106. Furthermore, during the inspection inquiry, the second defendant produced documentation that has been in the possession of the first defendant since the conclusion of the subcontracting agreement. These documents were produced because they were the subject of an exchange between the parties, which would demonstrate that the first defendant indeed exercised due diligence. The first defendant objects that the evidence from the Inspection Service does not clearly demonstrate that the documents related to security were only produced at the end of the Inspection inquiry and not prior to the processing of the data. Furthermore, the first defendant argues that the Inspection Service does not demonstrate that the only document related to the contractual documentation is the "sales brochure." The first defendant notes that the Inspection Service did not take note of its complete response. In its response, the first defendant had indeed indicated that the sales manager of the first defendant no longer worked for the company.

II.7.2. Evaluation by the Disciplinary Chamber

107. The data controller has the obligation to "only engage subprocessors who provide sufficient guarantees regarding the implementation of appropriate technical and organizational measures in such a way that the processing meets the requirements of the GDPR - including the security of processing - and ensures the protection of the rights of the data subjects."<sup>20</sup> It is therefore the

responsibility of the data controller to evaluate the measures taken by the subprocessor, and they must be able to demonstrate that they have seriously considered all the elements mentioned in the GDPR, what is referred to as the obligation of due diligence. This generally involves an exchange of documents such as, for example, the privacy statement, the general terms and conditions, and the record of processing activities.

108. The above evaluation must be carried out by the data controller on a case-by-case basis and will depend heavily on the type of processing entrusted to the subprocessor, taking into account the 20 Article 28, paragraph 1 and Recital 81 of the GDPR.

Decision on the Merits 114/2024 – 28/72

nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of natural persons.

109. The following elements must be considered by the data controller to evaluate the guarantees: the expertise of the subprocessor (for example, technical expertise regarding security measures and data breaches), the reliability of the subprocessor, and the resources of the subprocessor.<sup>21</sup> The reputation of the subprocessor in the market may also be a relevant factor for the data controller to consider. Furthermore, adherence to an approved code of conduct or certification mechanism may be used to demonstrate the existence of sufficient guarantees.

110. The obligation set out in Article 28.1 of the GDPR to only engage subprocessors "providing sufficient guarantees" constitutes a continuous obligation. It does not cease when the data controller and the subprocessor enter into a contract or another legal act. On the contrary, the data controller must verify at appropriate intervals the guarantees of the subprocessor, among other things through audits and inspections if necessary.<sup>22</sup>

111. The Disciplinary Chamber notes that the subcontracting agreement consists of three parts, as indicated in the conclusions of the second defendant, namely the main contract itself with 2 annexes (Enclosure 1 and Enclosure 2). Annex 2 of the main contract included two annexes, namely the 'Z IT Guide' and a document titled "data processing agreement." As also pointed out by the second defendant, the Disciplinary Chamber observes that the Z IT Guide was absent from the Inspection file, so it was not taken into account during the inquiry.

112. The Disciplinary Chamber believes that the description of these security measures allows the first defendant to demonstrate the necessary due diligence regarding the expertise of the second defendant as a subprocessor. Both the first defendant and the second defendant indicate that various exchanges took place between the two parties prior to the conclusion of the subcontracting agreement, but that the individuals involved no longer work for the companies. Therefore, no additional information can be provided about these exchanges. As far as necessary, the Disciplinary Chamber notes that, within the framework of the principle of accountability, such exchanges should ideally be documented so that there is clarity about them, even after the departure of the individuals concerned.

21 Recital 81 of the GDPR.

22 Article 28, paragraph 3, h) of the GDPR.

Decision on the merits 114/2024 – 29/72

113. In light of the above, the Disciplinary Chamber finds that the submitted documents, including the subcontracting agreement with its annexes, demonstrate that the first defendant was able to make the necessary efforts to assess the suitability of the second defendant as a subcontractor. Therefore, there is no violation of Article 28.1 of the GDPR.

II.8. Article 32 of the GDPR concerning the first defendant

II.8.1. Findings in the inspection report

114. During its investigation, the Inspection Service finds that there is a violation of Article 32 of the GDPR on the part of the first defendant as the data controller.

115. Article 5.1(f) of the GDPR prescribes that "[personal data] must be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures."

116. In continuation of Article 5.1(f) of the GDPR, Article 32.1 of the GDPR states that the data

controller must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk. In this regard, account must be taken of the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing as well as the likelihood and severity of the risks posed by the processing to the rights and freedoms of individuals.

117. Article 32.1 of the GDPR also states that when assessing the appropriate level of security, account must be taken of the risks presented by the processing, resulting in particular from the destruction, loss, alteration, unauthorized disclosure of personal data transmitted, stored, or otherwise processed, or from unauthorized access to such data, whether accidental or unlawful.

118. The Inspection Service asserts that the first defendant was unable to demonstrate that it had any information security policy or written procedures concerning the protection of personal data. Annex 10 of the 2022 version of the work regulations was not included in the version of the work regulations in force at the time of the disputed processing and was drafted after the first contact with the Inspection Service. Furthermore, according to the Inspection Service, the security measures included therein are not sufficiently concrete to allow the Inspection Service to assess their relevance.

Decision on the merits 114/2024 – 30/72

119. The record of processing activities, which was also established after the first contact with the Inspection Service, contains only the description that “only the HR department has access to this data. Personnel files are securely stored on the server and are physically kept in a locked cabinet to which only the HR department has the key. Time recording is processed on a separate computer to which only the HR department has access.” In a second letter from the Inspection Service to the first defendant, clarifications were again requested regarding the technical and organizational measures implemented in the context of information security. A second piece of evidence was provided by the first defendant, but the Inspection Service found that this evidence only demonstrated that the software of the second defendant allowed for refining the level of access within the first defendant using different roles. The manner in which access within the first defendant was concretely implemented cannot be established by the Inspection Service, which does not allow for the demonstration of the existence of an internal policy for logical access management to the data of the time recording system. The Inspection Service adds that a general information security policy is, in any case, lacking. According to the Inspection Service, there is therefore a violation of Article 32 of the GDPR.

II.8.2. Assessment by the Disciplinary Chamber

120. The first step in defining the appropriate level of security for the processing of personal data is to identify the risks of this processing and to establish a weighting. On this basis, it is necessary to determine what measures are required to provide sufficient security against these risks. It follows from the GDPR that for the weighting of risks in terms of data security, attention should be paid to the risks that may arise during the processing of personal data, such as unauthorized disclosure or unauthorized access to the processed data. When inventorying and assessing risks, it is primarily the consequences of unlawful processing of personal data that individuals may suffer that are relevant. Depending on whether the data is of a more sensitive nature, or if the context in which it is used poses a greater threat to privacy, stricter requirements are imposed for the security of personal data.

121. Based on the inspection report, the Disciplinary Chamber finds that there was no general information security policy available concerning the processing of biometric data. After the first contact with the Inspection Service, the first defendant adapted its record of processing activities and included security measures therein.

Decision on the merits 114/2024 – 31/72

122. Regarding technical measures, the Contentious Chamber notes that the second defendant, as the system provider, implements the necessary encryption (ISO certified). Based on the inspection report, the Contentious Chamber finds that several organizational measures have been taken, such as limiting the number of employees who have access to this personal data, restricting the access area where the personal data was located, storing personal data on a server in a locked room, and keeping paper personnel records in a locked room.

123. Concerning the findings related to the security measures monitoring policy, the Contentious Chamber emphasizes that it is important to distinguish between the security measures themselves and

their documentation within the accountability principle. Regarding the security measures per se, the Contentious Chamber finds that they meet the requirements of Article 32 of the GDPR. In light of the above, the Contentious Chamber finds no violation of Article 32 of the GDPR.

11.9. The data protection impact assessment (Article 35 of the GDPR) regarding the first defendant  
124. The Inspection Service concludes in its inspection report that it is unclear whether the first defendant claims that it was not required to carry out a data protection impact assessment (hereinafter: DPIA) because the processing was not likely to present a high risk within the meaning of Article 35.1 of the GDPR, or whether it conducted a DPIA that concluded there was no high residual risk within the meaning of Article 36 of the GDPR. In either case, the Inspection Service finds that the first defendant did not act in accordance with the GDPR.

125. The first defendant has not taken a position on this matter.

126. In accordance with Article 35.1 of the GDPR, the data controller must carry out, prior to processing, an assessment of the impact of the intended processing operations on the protection of personal data when the processing, particularly by means of new technologies, and taking into account the nature, scope, context, and purposes of the processing, is likely to result in a high risk to the rights and freedoms of natural persons.

127. As stated in point 6 of decision no. 01/2019, a DPIA must always be conducted when the processing uses biometric data for the unique identification of data subjects located in a public place or in a private place accessible to the public. However, the Knowledge Centre of the DPA emphasizes in its recommendation that the processing of biometric data for purposes other than those...

Decision on the merits 114/2024 – 32/72

expressly reiterated in decision 01/2019 of the General Secretariat is also subject, where applicable, to the obligation to carry out a DPIA. Moreover, given the high inherent risk to the rights and freedoms of the data subjects involved in the processing of biometric data, not conducting a DPIA will only be justified in exceptional cases.

128. In accordance with Article 35 of the GDPR, a DPIA must be carried out when a processing of personal data is likely to result in a high risk to the rights and freedoms of the data subjects. In assessing the necessity of a DPIA, several factors must be taken into account, such as the nature, scope, context, and purposes of the processing, as well as the potential risks to the rights and freedoms of the data subjects.

129. To provide a more concrete view of processing operations that require a DPIA due to a high inherent risk, considering the specific elements of Articles 35.1 and 35.3, points a) to c), of the list to be established at the national level under Article 35.4, and Recitals 71, 75, and 91, as well as other references in the GDPR to processing operations "likely to result in a high risk," Working Party 29 has developed the following nine criteria that should be taken into account.<sup>23</sup>

130. The Contentious Chamber finds that most of these criteria are met, namely:

-

First criterion: assessment, including profiling and prediction activities, particularly concerning "aspects related to the performance at work of the data subject." This condition is met because the recording of a worker's working time is a characteristic related to professional performance.

-

Second criterion: automated decision-making with legal effect or similar significant effect. As already explained, the workers of the first defendant had no demonstrated alternative in terms of recording working time, and no salary could be paid if the workers did not record their working time.

-

Fourth criterion (sensitive data or highly personal data). This includes, among other things, the special categories of personal data referred to in Article 9 of the GDPR, including biometric data used for identification purposes.

-

Fifth criterion (data processed on a large scale). The GDPR does not specify what is meant by "on a large scale," but Working Party 29 recommends considering factors such as the number of data subjects, either in absolute terms or in proportion to the population concerned.<sup>24</sup> In the present case,

the recording of time by fingerprint concerns all workers of the first defendant, so it may involve large-scale processing.

-

Seventh criterion: data concerning vulnerable individuals. As indicated, the workers are, in this case, vulnerable data subjects because they are in a dependency relationship with the first defendant as their employer.

131. In most cases, a data controller can assume that if processing meets two criteria, a DPIA must be conducted. As explained above, five of the defined criteria are met. The Contentious Chamber adds that the use of biometric data for recording the working time of workers may pose significant risks to the privacy of the data subjects, such as the high risk of unauthorized access, hacking, and identity theft. In light of the above, the Contentious Chamber finds that the first defendant should have conducted a DPIA, which constitutes a violation of Article 35 of the GDPR.

II.10. Transfer to third countries or to international organizations (Chapter V of the GDPR) concerning the first defendant

II.10.1. Findings in the inspection report

132. The Inspection Service finds that according to the documents, the servers used are solely located on Belgian territory. The first defendant also states in its response and in its processing activities register that no transfer takes place. According to the response from the second defendant, templates cannot be extracted by the first defendant, which seems to exclude the risk of any potential transfer of these files by the first defendant. Therefore, the Inspection Service concludes that there is no indication of potential transfers of biometric data to third countries or to international organizations.

II.10.2. Evaluation by the Contentious Chamber

133. As already indicated, the Inspection Service sees no indication of potential transfers of biometric data to third countries or to international organizations. The Contentious Chamber has no indication to judge otherwise. Therefore, the Contentious Chamber finds that there is no violation of Chapter V of the GDPR.

23 Working Party 29, "on the impact assessment regarding data protection (DPIA) and how to determine whether processing is 'likely to result in a high risk' for the purposes of Regulation (EU) 2016/679, ratified on October 4, 2017 (WP 248 rev. 01), p. 9 e.s.

24 Guidelines of Working Party 29 regarding data protection officers 16/FR WP 243.  
Decision on the merits 114/2024 – 34/72

II.11. Register of processing activities (Article 30 of the GDPR) concerning the first defendant

II.11.1. Findings of the Inspection Service

134. The Inspection Service finds that the register of processing activities provided is dated after the first contact with the Inspection Service. The Inspection Service arrives at this conclusion based on the following elements. The register of processing activities mentions the email address [dataprotection@benepack.com](mailto:dataprotection@benepack.com) as the contact address of the data controller. However, this address was only created after the first contact with the Inspection Service. Given that the first defendant states during the inspection inquiry that this is the only version of the register of processing activities, the Inspection Service concludes that the first defendant did not have a register of processing activities prior to the inspection inquiry. The Inspection Service finds that this constitutes a violation of Article 30 of the GDPR, as the first defendant must maintain a register of processing activities at least for the processing concerning its personnel. Indeed, the processing cannot be considered occasional within the meaning of Article 30.5 of the GDPR. Furthermore, the Inspection Service notes that the first defendant processes special categories of personal data and criminal data.

135. Moreover, according to the findings of the Inspection Service, the register of processing activities is deficient in several respects. The CEO and the human resources manager of the first defendant are presented as data protection officers (Article 30.1.a) of the GDPR). The purposes of processing listed in the register of processing activities differ in several respects from the purposes of processing included for these processes in the work regulations (June 2022 version) (Article 30.1.b) of the GDPR). The ten categories of personal data that appear in the work regulations (June 2022 version) are not or

not fully included in the register of processing activities (Article 30.1.c) of the GDPR), and internal collaborators are presented as subcontractors while, for example, the subcontractor for the biometric time recording system is not mentioned (Article 30.1.d) of the GDPR).

#### II.11.2. Assessment by the Contentious Chamber

136. Under Article 30 of the GDPR, every data controller must maintain a register of processing activities carried out under its responsibility. Article 30.1.a) to g) inclusive of the GDPR states that, with regard to processing carried out as a data controller, the following information must be available:

##### Decision on the merits 114/2024 – 35/72

- a) the name and contact details of the data controller and any joint controllers, and, where applicable, the representative of the data controller and the data protection officer;
- b) the purposes of the processing;
- c) a description of the categories of data subjects and the categories of personal data;
- d) the categories of recipients to whom the personal data have been or will be disclosed, including recipients in third countries or international organizations;
- e) where applicable, the transfers of personal data to a third country or to an international organization, including the identification of that third country or international organization and, in the case of transfers referred to in Article 49(1), second paragraph of the GDPR, the documents evidencing the existence of appropriate safeguards;
- f) where possible, the envisaged time limits for erasure of the different categories of data;
- g) where possible, a general description of the technical and organizational security measures referred to in Article 32.1 of the GDPR.

137. Regarding the name and contact details of the data protection officer (Article 30.1.a) of the GDPR), the Contentious Chamber finds, in accordance with the inspection report, that the register of processing activities does indeed mention the contact details of the CEO and the human resources manager as data protection officers.

138. Regarding the purposes of the processing (Article 30.1.b) of the GDPR), the Contentious Chamber finds that the purposes mentioned in the register of processing activities do not correspond to the purposes listed in the work regulations (June 2022 version). The register of processing activities mentions as a purpose of processing for fingerprints: "are recorded for time recording. At the beginning and end of the workday, workers must clock in and out using their fingerprints." The work regulations (June 2022 version) mention not only the recording of working time but also the fight against fraud and the safety of personnel. Regarding the surveillance cameras as well, the Contentious Chamber notes a discrepancy between the purposes of processing. The register of processing activities emphasizes "security and health," while the work regulations (June 2022) focus on "monitoring in the workplace: to ensure the safety of all personnel, combat potential fraud,

##### Decision on the merits 114/2024 – 36/72

the offenses and potential violations by third parties; and the protection of the company's assets" as processing purposes.

139. Regarding the categories of personal data (Article 30.1.c) of the GDPR), the Contentious Chamber notes that the work regulations mention several categories of personal data processed, which are not included in the register of processing activities. These categories are as follows: contact details of persons to be contacted in case of emergency, current (and previous) position of persons employed by the first defendant, bonuses and salary benefits, company property in the possession of the data subject (mobile phone, company car, laptop, etc.), information concerning the data subject in the context of benefits management, training and development, occupational health and workplace accidents, information provided by the data subject or relating to the data subject in the context of the internal whistleblowing procedure, and finally, information regarding certain offenses, such as traffic accidents that may engage the liability of the data subject or the first defendant. The categories "image recordings by means of surveillance cameras and information provided by the data subject or relating to the data subject in the context of pension accounts, pensions, hospitalization insurance, and other information on benefits" are incompletely included in the register of processing activities.

140. Finally, the Contentious Chamber notes that the second defendant, in its capacity as a

subcontractor within the biometric time recording system, is not mentioned as a recipient in the register of processing activities (Article 30.1.d) of the GDPR).

141. In order to effectively apply the obligations contained in the GDPR, it is essential that the data controller (and the processors) have an overview of the processing of personal data they carry out. This register thus primarily serves as a tool to assist the data controller in complying with the GDPR for the various data processing activities they perform. The Contentious Chamber believes that the register of processing activities is an essential instrument within the framework of the accountability principle already mentioned (Article 5.2 and Article 24.1 of the GDPR) and that this register is the basis for all obligations imposed by the GDPR on the data controller. It is therefore important that this register is complete and accurate.

142. The Contentious Chamber finds that the register of processing activities submitted by the first defendant is incomplete and partially inaccurate, as noted in the inspection report. In this context, the Contentious Chamber points out that, although the first defendant does indeed undertake  
Decision on the merits 114/2024 – 37/72

currently taking steps to rectify these violations, too little effort has been made to develop the register of processing activities in accordance with the provisions of Article 30 of the GDPR. The Contentious Chamber therefore finds that there is a violation of Article 30.1.a), b), c), d) of the GDPR.

II.12. Liability (Article 5.2 of the GDPR) of the first defendant

143. The Contentious Chamber recalls that each data controller must comply with the basic principles of personal data protection, as defined in Article 5.1 of the GDPR, and must be able to demonstrate compliance with these principles. This derives from the principle of accountability set out in Article 5.2 of the GDPR in conjunction with Article 24.1 of the GDPR, as confirmed by the Contentious Chamber.

144. Under Articles 24 and 25 of the GDPR, the data controller must take appropriate technical and organizational measures to ensure and be able to demonstrate that processing is performed in accordance with the GDPR. In this context, it must effectively apply the principles of data protection, safeguard the rights of data subjects, and only process personal data that is necessary for each specific purpose of processing.

145. In the course of its investigation, the Inspection Service assessed the extent to which the first defendant has taken the necessary technical and organizational measures to comply with these principles of Article 5.1 of the GDPR, particularly the principles of lawfulness and transparency, purpose limitation, data minimization, and storage limitation (see points II.1 to II.6).

146. Furthermore, the Contentious Chamber notes that the description in point II.8 of the security measures taken does not show how adequate control of these measures is organized, nor does it specify to what extent the first defendant verifies whether the measures are effective and how frequently this is checked. Finally, no policy has been established for the effective management of information security incidents. The Contentious Chamber believes that the sensitive nature of the biometric data processed on a large scale by the first defendant should have prompted it much earlier to better comply with the aforementioned principles of the GDPR (including data security), particularly by anticipating the inherent risks of such violations.

147. It follows from the above that the technical and organizational measures taken following the installation and commissioning of the time recording system using biometric data were not appropriate to ensure compliance with the fundamental principles of the GDPR, and more specifically the principles of lawfulness, purpose limitation,

via  
the  
following  
link:

<https://www.autoriteprotectiondonnees.be/professionnel/publications/decisions>.

Decision on the merits 114/2024 – 38/72

purposes, transparency, and data minimization. As the data controller, the first defendant did not take appropriate measures, or sufficiently appropriate measures, to ensure and demonstrate that the processing in question was carried out in accordance with the GDPR, resulting in a violation of Article 5.2 of the GDPR.

II.13. Article 28.3 of the GDPR concerning the second defendant

II.13.1. Findings in the inspection report

148. The Inspection Service notes in its report that the subcontracting agreement between the first and second defendants does not meet the requirements of Article 28.3 of the GDPR, as it only contains a description of general security measures, and not a detailed description focused on the high security requirements when processing biometric data. According to the Inspection Service, the subcontracting agreement itself includes, on the one hand, the legal provisions of Article 32.1 of the GDPR and refers to the annex for further details. According to the Inspection Service, this Annex B contains a concrete description, but still succinct and insufficiently tailored to the specific nature of the data processed. This generality and the limited level of detail in Annex B do not allow for determining, for example, the level of encryption applied to the raw biometric data or stored as a template, the use of a verification function or an identification function in the comparison phase of the biometric authentication process, the system used by the subcontractor for the deletion and destruction of biometric data after the retention period expires, and the precise terms of the logical and physical access policies applied by the subcontractor.

149. According to the inspection report, the subcontracting agreement also has shortcomings regarding the definition of the nature and purpose of the processing and the type of personal data processed, as required by Article 28.3 of the GDPR.

150. Regarding the nature and purpose of the processing, the Inspection Service finds that it is impossible to verify them based on the provisions of the subcontracting agreement. The only purpose that can be inferred is the execution of the service contract between the two defendants. From the service contract itself, the Inspection Service can at most deduce the processing of fingerprints and time recording data of the workers. The subcontracting agreement does not allow the Inspection Service to clarify the type of personal data processed by the second defendant on behalf of the first defendant. The contract only contains an open dropdown menu as well as 20 fields to be freely completed by the client. The client also did not indicate any choice of categories to be processed.

Decision on the Merits 114/2024 – 39/72

151. The Inspection Service places particular importance on the role of the subcontractor in fulfilling this joint obligation under Article 28.3 of the GDPR because the subcontractor is the only party that possesses the technical knowledge necessary for a complete description of the processing. Without this complete description, neither the data controller nor the supervisory authority can properly assess the content and risks of the processing entrusted to the subcontractor.

152. The Inspection Service notes that, even at its explicit request, the subcontractor (the second defendant) is unable to provide a complete technical description of the processing entrusted to it. This is evident from its minimal response to the Inspection Service's question regarding the operation of the time recording system. Furthermore, the second defendant appears unable to provide additional information on certain elements such as: the encryption of raw biometric data and templates, the presence of integrity checks related to biometric data, the precise technical modalities of the collection and comparison phases of the biometric authentication process, and the technique used for the erasure and destruction of data after the retention period has expired.

153. In its report, the Inspection Service also refers to paragraph 103 of the EDPB Guidelines 07/2020 concerning the concepts of data controller and processor in the GDPR26, which states that both the data controller and the processor are responsible for ensuring that a contract or other legal act governs



the processing. The competent supervisory authority may impose an administrative fine on both the data controller and the processor, taking into account Article 83 of the GDPR and the circumstances specific to each situation. Contracts concluded before the GDPR's entry into force should have been adapted in accordance with Article 28.3 of the GDPR. Failing to do so constitutes a violation of the provision in question.

154. Finally, according to the Inspection Service, the second defendant challenges the legal qualification of the personal data it processes (in the context of the disputed processing) as biometric data. However, the subcontracting contract refers to the biometric templates of the personal data processed by the second defendant. The Inspection Service disagrees with this statement. Therefore, the Inspection Service has doubts regarding the technical and organizational measures taken by the second defendant, as under Article 32.1 of the GDPR, they must be appropriate to the risk of processing, which has apparently been poorly assessed by the second defendant.

26 Guidelines 07/2020 on the concepts of data controller and processor in the GDPR, version 2.0, adopted by the EDPB on July 7, 2021, available via the following link: [https://www.edpb.europa.eu/system/files/2023-10/edpb\\_guidelines\\_202007\\_controllerprocessor\\_final\\_fr.pdf](https://www.edpb.europa.eu/system/files/2023-10/edpb_guidelines_202007_controllerprocessor_final_fr.pdf).

Decision on the merits 114/2024 – 40/72

155. The Inspection Service concludes that the subcontracting contract is not compliant with Article 28.3 of the GDPR in that it does not meet the minimum requirements of this provision, notably the definition of the nature and purpose of the processing, the type of personal data, and the technical and organizational measures applied by the processor.

II.13.2. Position of the second defendant

156. In its conclusions, the second defendant argues that it indeed has the capacity to share the appropriate knowledge about the system. It provided the relevant information to the first defendant in a timely manner. At the time of the conclusion of the contract, the first defendant had documentation and detailed information in the subcontracting contract and had access to the online platform, and it also received several training sessions. Furthermore, it is the first defendant who registers individuals in the system. The processing of personal data therefore began as soon as the first defendant started this registration. Consequently, the first defendant was able to become aware of all the available information regarding the processes before commencing the processing. Regarding its minimalist response to the Inspection Service, the second defendant points out that immediately after it was questioned for the first time, the Inspection Service closed the investigation and prepared the inspection report; however, the first defendant was questioned more than once.

157. Moreover, the second defendant objects that the Inspection Service has created an incomplete file. The Inspection Service only requested the subcontracting contract from the first defendant, which the first defendant provided, but without the Z IT Guide. This Z IT Guide is fully part of the subcontracting contract as an annex. The second defendant was not aware that an incomplete subcontracting contract had been communicated, and no questions were asked of it regarding this matter. Furthermore, the second defendant criticizes the fact that the Inspection Service questioned it not only about the processing tasks assigned to it but also about the tasks and processing of the first defendant. The second defendant argues that the Inspection Service reproaches it, regarding the incompleteness of its response (which it denies, according to the second defendant), for not providing a complete technical description of the processing carried out by the first defendant, which it is not obliged to do. The reference by the Inspection Service to paragraph 103 of the guidelines 07/2020 was only adopted in July 2021, so this paragraph was not yet present in the 2020 version. In this regard, it is important to emphasize that the subcontracting contract was concluded on February 14, 2020. Therefore, any failure to respond by the first defendant, as far as it has already been noted, cannot be attributed to the second defendant, but the Inspection Service must question the first defendant about this.

Decision on the Merits 114/2024 – 41/72

158. Furthermore, the second defendant points out that it is criticized for not having provided information on the technique used for the erasure and destruction (for example, overwriting, degaussing, cryptographic erasure, etc.) of data after the retention period has expired, citing

recommendation 03/2020 from the Data Protection Authority (APD). The Inspection Service reached this conclusion following a response from the second defendant to the question "What system is used for the erasure and destruction of data/biometric templates after the retention period has expired? Who is responsible for this erasure [first defendant] or [second defendant]?". The second defendant replied that no raw biometric data is retained. The encrypted templates are stored on the ST25 terminal and in the SQL cloud database as long as the worker exists in the SQL cloud database. Distribution on one or more ST25 terminals is carried out based on the configuration in the T&A; web application of Z. The second defendant notes that this response has apparently not been considered conclusive by the Inspection Service. The second defendant observes that the Inspection Service could have asked a follow-up question on this matter if it deemed the provided answer insufficient.

159. The legal qualification of the data processed by the subcontractor is a point of contention between the second defendant and the Inspection Service. The second defendant believes that, with Z, it does not process biometric data or any other special category of personal data. The second defendant points out that biometric data (Article 4.14 of the GDPR) only constitutes a special category under Article 9 of the GDPR if it is processed for the purpose of unique identification. The second defendant asserts that no comparison is made on the online platform it provides. The comparison of biometric data occurs only in the specific reader, which is linked to the terminals at the client's site, in this case, the first defendant. Only the reader, as a separate module, contains proprietary software with secret algorithms whose functioning is known only to the module's supplier; the technology used constitutes a trade secret. The manufacturer does not disclose how the templates are created, nor what key is used for encryption. However, the manufacturer confirms that they are never disclosed. The second defendant adds that it is impossible for anyone to use the data provided by the biometric reader to identify a person during user registration. The only thing the file allows is to be relayed to a reader of the same manufacturer within the system in order to obtain as a response the verification of an identity (match or no match). Thus, the only response that a reader will provide is a match with a known identifier or a lack of match. Anyone who were to illegally obtain the encrypted data file from the biometric reader after

Decision on the merits 114/2024 – 42/72

The registration of a user could not use this file in any other type of biometric tool, as it would not have the unique key(s). Consequently, the second defendant concludes that it offers an online storage system, but does not choose which terminals on-site at the first defendant store certain data related to biometrics, and certainly does not organize the comparison phase on its own platform (online). It is merely the service provider for the preservation of a file from which no one can obtain decryption without hacking the manufacturer's reader.

160. The second defendant also argues that it is reasonably impossible for it to obtain the decryption information, which raises the question of whether the files actually constitute personal data within the meaning of Article 4.14 of the GDPR.

#### II.13.3. Assessment by the Contentious Chamber

161. Any processing of personal data by a processor must be governed by a contract or another legal act under EU law or the law of a Member State between the data controller and the processor, as required by Article 28.3 of the GDPR.

162. The Inspection Service finds several violations of Article 28.3 of the GDPR: (i) the subcontracting contract between the first defendant as the data controller and the second defendant as the processor does not comply with the requirements of Article 28.3 of the GDPR, particularly regarding the minimum requirements related to the definition of the nature and purpose of the processing, the type of personal data, and the technical and organizational measures applied by the processor; (ii) the second defendant does not meet the obligations under Article 28.3 of the GDPR given that while it was the only one with the technical knowledge of the system, it nevertheless insufficiently defined the processing and finally, it would have questioned the legal qualification of biometric data.

(i) Description of the nature and purpose of the processing, the type of personal data, and the technical and organizational measures applied

163. First, the Contentious Chamber examines to what extent the subcontracting contract between the first defendant as the data controller and the second defendant as the processor meets the

requirements of Article 28.3 of the GDPR, particularly regarding the minimum requirements related to the definition of the nature and purpose of the processing, the type of personal data, and the technical and organizational measures applied by the processor. 27

27 See finding 12 of the inspection report.

Decision on the Merits 114/2024 – 43/72

164. The Dispute Chamber notes that the subcontracting contract consists of several parts, as indicated in the conclusions of the second defendant, namely the main contract itself with 2 annexes (Enclosure 1 and Enclosure 2). Enclosure 2 of the main contract also contains 2 annexes, namely Attachment 1: “Z IT Guide” and Attachment 2: “Data processing agreement,” which again includes 3 annexes: Attachment A (description of the processing), Attachment B (technical and organizational security measures), and Attachment C (subprocessors).

165. Referring to the guidelines 07/2020 regarding the concepts of “data controller” and “processor” in the GDPR, the Dispute Chamber recalls that the subcontracting contract must include, among other things, the following elements: a description of the type of personal data and categories of data subjects as well as the nature of the processing. Regarding the nature and purpose of the processing, the EDPB specifies that this description should be as complete as possible, depending on the processing activity concerned, in order to allow external parties (for example, supervisory authorities) to understand the content and risks of the processing entrusted to the processor. The “description of the processing” as included in Attachment 2 of the subcontracting contract states that the contract concerns the retention of various categories of personal data and sensitive data. The subcontracting contract and all its annexes indirectly suggest that it involves the processing of fingerprints and the recording of workers' time, notably from Enclosure 1 of the subcontracting contract which mentions Fingerprint licenses and indicates that all information provided by the client (in this case, the data controller) related to time recording will be stored in Z's database for a specified period.

166. According to the EDPB, the types of personal data should be specified in the most detailed manner possible. Simply stating that it concerns personal data within the meaning of Article 4.1 of the GDPR or specific categories of personal data within the meaning of Article 9 of the GDPR would not suffice. The Dispute Chamber notes that the subcontracting contract included in Enclosure 2 “Description of the processing” allows for the possibility of indicating which personal data is involved.

Decision on the merits 114/2024 – 44/72

Personal data will be specifically processed based on the subcontracting agreement [“Please select the categories you intend to use with the Services”]. Among these, the subcontracting agreement also provides for four categories of special personal data processed by the second defendant based on the subcontracting agreement. Here too, it is requested to indicate the relevant categories [“Please select the categories you intend to use with the services”]. The Contentious Chamber notes that the relevant categories have not been indicated for either personal data or special personal data. The Contentious Chamber observes that this violation was only attributed to the second defendant by the Inspection Service, whereas the obligations of Article 28.3 of the GDPR apply to both contracting parties. Nevertheless, the absence of designation could also be attributed to the first defendant since, as the data controller, it determines the purposes and means of processing.

167. In conclusion, the Contentious Chamber finds that the information required under Article 28.3, paragraph 1 (the nature and purpose of the processing and the type of personal data) can be inferred from a full reading of the subcontracting agreement, but it is recommended, for the sake of clarity, that the (categories of) personal data processed, whether special or not, be indicated in the annex as provided.

168. The Inspection Service also noted in its report that there is a violation of Article 28.3(c) of the GDPR, given the general nature and limited degree of detail in the enumeration of the technical and organizational measures applied.

169. Article 28.3(c) of the GDPR requires that all security measures required under Article 32 of the GDPR be reflected in the subcontracting agreement. This subcontracting agreement cannot simply repeat the provisions of the GDPR but must contain information about the security measures or references to those measures. The level of detail must allow the data controller to assess the

adequacy of the measures in accordance with Article 32.1 of the GDPR.<sup>31</sup>

170. Article 32.2 of the GDPR states that when assessing the appropriate level of security, account must be taken of the risks presented by the processing, resulting in particular from the destruction, loss, alteration, unauthorized disclosure of personal data transmitted, stored, or otherwise processed, or from unauthorized access to such data, whether accidental or unlawful. In this regard, it is also necessary to consider the particular nature or not of the personal data.

31 Guidelines 07/2020 on the concepts of controller and processor in the GDPR, version 2.0, adopted by the EDPB on July 7, 2021, para. 126, available via the following link: [https://www.edpb.europa.eu/system/files/2023-10/edpb\\_guidelines\\_202007\\_controllerprocessor\\_final\\_fr.pdf](https://www.edpb.europa.eu/system/files/2023-10/edpb_guidelines_202007_controllerprocessor_final_fr.pdf).

Decision on the merits 114/2024 – 45/72

personal data processed, which constitutes a point of disagreement between the Inspection Service and the second defendant.

171. Regarding the qualification of the personal data processed by the second defendant, the Contentious Chamber recalls the definition of biometric data and the processing of a potential special category of personal data. As also indicated by the second defendant in its conclusions, biometric data does not inherently constitute a special category of personal data within the meaning of Article 9 of the GDPR. For this to be the case, the purpose of unique identification is required. As previously stated, the purpose of identification is present on the part of the first defendant as the data controller in the context of time recording, but not on the part of the second defendant. The latter receives data from the first defendant that it processes (i.e., stores) without the purpose of identification or authentication, so there is no question of processing special personal data within the meaning of Article 9 of the GDPR. The applicable security measures must therefore be adapted accordingly.

172. As already explained, the subcontracting contract consists of the main contract and 2 annexes (Attachment 1 and Attachment 2). As also indicated by the second defendant, the Contentious Chamber notes that the Z IT Guide (Attachment 2) was missing from the Inspection file, so it was not taken into account during the investigation.

173. This Z IT Guide explains in 13 pages the aspects related to the security of the Z application, providing concrete information on the security measures taken for the processing entrusted to it, namely the storage of data in Z. This guide contains information about the servers on which the data is stored, the security measures (such as antivirus systems, firewalls, SSL certificates, and monitoring services). The Contentious Chamber believes that the level of detail in the description of the security measures meets the requirements imposed by Article 28.3.c) of the GDPR.

(ii) the second defendant does not meet the obligations under Article 28.3 of the GDPR given that while it was the only one with the technical knowledge of the system, it nevertheless insufficiently defined the processing and ultimately questioned the legal qualification of biometric data.

174. The Contentious Chamber observes that these findings do not concern the content of the subcontracting contract as defined in Article 28.3 of the GDPR, but rather the exchanges of pre-contractual information with the first defendant (for example, based on Article 28.1 of the GDPR) or the principle of accountability under Article 5.2 of the GDPR.

Decision on the Merits 114/2024 – 46/72

175. Regarding the finding that the second defendant did not sufficiently describe the processing, the Contentious Chamber refers to point II.7 where it notes that the subcontracting contract was not fully communicated to the Inspection Service by the first defendant. The second defendant was not asked to provide the subcontracting contract to the Inspection Service.

176. As explained, the Z IT Guide contains information on the technical knowledge of the system. The second defendant transferred all this information to the first defendant, who is responsible for the processing, based on which the latter was able to carry out the required analysis in this regard (see point II.8). Furthermore, the second defendant also offered training on the operation of Z. Additionally, the Contentious Chamber notes that further documentation, a portal, and a help function were also available online, as well as a helpdesk. As the second defendant also points out, the registration of workers only begins when the first defendant activates it. Therefore, it could request additional information if necessary before starting time registration. The Contentious Chamber thus considers

that the processing is sufficiently described and that the second defendant has provided the necessary information to the first defendant.

177. The Inspection Service also notes that, even upon explicit request from the Inspection Service, the second defendant is unable to provide a complete technical description of the processing entrusted to it. In this regard, the Inspection Service refers to the minimalist responses of the second defendant and its inability to provide additional information on certain elements.

178. The Contentious Chamber first notes that a possible minimalist response to the Inspection Service two years after the conclusion of the subcontracting contract has no impact on the correct or incorrect compliance with Article 28.3 of the GDPR, which only defines the content requirements of the subcontracting contract.

179. The Contentious Chamber further notes that, in its letter dated July 6, 2022, the Inspection Service requested the second defendant to explain the technical operation of the system and, in particular, how the biometric data collected through the system is processed. On this occasion, the Inspection Service requested that this explanation be accompanied by an overview as schematic as possible of the different stages of processing, from collection to deletion. Furthermore, the Inspection Service requested clarification on what technical and organizational security measures are taken by the second defendant to protect the integrity, availability, and confidentiality of the data, whereas it is actually the first defendant that bears these obligations. Subsequently, the Inspection Service posed Decision on the merits 114/2024 – 47/72

12 additional questions. These questions also concern the different phases of time recording.

180. The Dispute Chamber notes that the second defendant has answered the 12 questions but was unable to respond to all questions on the merits. Some information is indeed not known to the second defendant, given that it is not responsible for processing throughout the entire chain of processing related to the time recording in question. The second defendant provided a response to the questions that pertained to the processing tasks assigned to it in its capacity as a subcontractor. In this regard, the second defendant also indicated why it could not answer the other questions, for example, because it did not process certain aspects of the time recording chain.

181. In light of the above, the Dispute Chamber concludes that there is no violation of Article 28.3 of the GDPR on the part of the second defendant.

II.14. Data Protection Officer (Article 37.1, b) and c) of the GDPR) concerning the second defendant

II.14.1. Findings in the inspection report

182. The Inspection Service notes in the inspection report that the second defendant does not comply with the obligations related to the designation of a data protection officer as defined in Article 37.1.b) and c) of the GDPR. Firstly, the Inspection Service states that the requirements for the designation of a data protection officer under Article 37.1.c) of the GDPR are met since it processes biometric data, the processing is carried out on a large scale, and it is the main responsible party. Therefore, the Inspection Service concludes that a data protection officer should have been designated.

183. Firstly, the Inspection Service does not share the second defendant's view regarding the fact that it does not process biometric data (see point II.13). Next, the Inspection Service refers to the standard clause in Annex A of the subcontracting agreement in which, as a subcontractor, the second defendant also opens itself to the processing of other categories of personal data. Secondly, regarding the large-scale nature of the processing, the Inspection Service notes that it is evident from the second defendant's board report that Z is distributed in 9 European countries, which allows the Inspection Service to understand that there is significant geographical coverage. The Inspection Service states that it has no idea of the number of individuals concerned or the amount of data processed, but further notes that the duration and permanence of the data processing inherent to a time recording system...

**\*\*Decision on the Merits 114/2024 – 48/72\*\***

constitutes an additional element in the assessment of the large-scale nature of the processing.

Thirdly, regarding the principal criterion, the Inspection Service states that it is clear that the processing of data constitutes a core activity of the company and not a supporting function necessary for the main activity of the organization.

184. Finally, the Inspection Service notes that it can also be considered based on Article 37.1.b) of the GDPR that the second defendant is required to appoint a data protection officer since the daily

recording of workers' arrival and departure times at a specific workplace constitutes regular and systematic monitoring of the data subjects.

**\*\*II.14.2. Position of the Second Defendant\*\***

185. The second defendant argues in its conclusions that it is in no way obliged to appoint a data protection officer, whether based on Article 37.1.c) of the GDPR or based on Article 37.1.b) of the GDPR.

186. Regarding the applicability of Article 37.1.c) of the GDPR, the second defendant contends that the arguments of the Inspection Service are not based on objective findings but that its analysis stems from half-hypotheses and erroneous interpretations. Concerning the processing of a particular category of personal data, the second defendant reiterates its assertion that the existence of biometric data processing and a particular category of personal data in the context of processing for the first defendant can be questioned. The second defendant adds that the Inspection Service has extrapolated its conclusions to the entirety of the operations and all activities of the second defendant. The second defendant emphasizes that its activities are divided between services related to parking systems and time recording. The figures for the 2021 financial year indicate that 74.29% of the revenue comes from parking systems and 25.71% from time recording. Time recording as such also goes beyond the Z services. The share of the second defendant in the total revenue of Z was only 8.50% in 2021.

The second defendant denounces the assumption of the Inspection Service that for Z, the second defendant would always resort to biometric readers and would therefore implement for other clients a Z solution using biometric readers. It emphasizes that only 10.93% of the revenue is specifically generated by projects related to Z where biometric readers are also used. The second defendant questions whether there are serious indications that these projects using biometric readers involve the processing of a particular category of data. If there were processing of a particular category of personal data,

**Decision on the merits 114/2024 – 49/72**

personnel, which the second defendant disputes, this does not necessarily have to be the case for other clients using application Z.

187. Regarding the large-scale nature, the second defendant criticizes the fact that the Inspection Service deduces the large-scale nature, among other things, from the fact that Z is marketed in 9 countries. The second defendant emphasizes that not all Z solutions work with biometric readers and that only the solutions that actually process specific categories of data can be considered to assess the large-scale nature. The second defendant contests that, based on an investigation in which the Inspection Service concludes that it has no idea of the number of affected individuals or the amount of data processed but notes that the duration and permanence of the data processing inherent in the recording of working time constitute an additional element for assessing the large-scale nature of the processing, one can conclude that the processing has a large-scale character.

188. The second defendant finally refers to the finding of the Inspection Service that the criterion of the main activity relates to the main activity of the subcontractor and not to a related activity. It questions whether the processing consisting of storing the specific category in the context of its activities should be considered a main activity. In this regard, it refers to the preparatory works of the GDPR which specify that by main activities, it is meant: "the activities in the context of which 50% of the annual turnover resulting from the sale of data or revenues are generated by the use of that data." This means conversely that data processing activities that do not generate more than 50% of a company's turnover are considered related activities. The second defendant draws attention to the fact that the turnover generated by Z and involving biometric readers represented only 0.93% of its turnover in 2021. Therefore, it is not a question of a main activity.

189. Regarding the alleged obligation to appoint a data protection officer based on Article 37.1.b) of the GDPR, the second defendant emphasizes that the cumulative conditions of main and large-scale nature are not re-verified. Furthermore, the second defendant points out that it is not the one conducting regular and systematic monitoring in the context of the disputed processing, if indeed it is the case.

**II.14.3. Assessment by the Litigation Chamber**

190. Under Article 31.7 of the GDPR, the appointment of a data protection officer is mandatory in three specific cases:

Decision on the Merits 114/2024 – 50/72

- a) when the processing is carried out by a public authority or a public body;
- b) when the core activities of the data controller or the processor consist of processing operations that, by their nature, scope, and/or purposes, require regular and systematic monitoring of data subjects on a large scale; or
- c) when the core activities of the data controller or the processor consist of large-scale processing of special categories of data referred to in Article 9 and personal data related to criminal convictions and offenses.

191. For the designation of a data protection officer, Article 37 of the GDPR applies to both data controllers and processors. Depending on who meets the criteria for mandatory designation, in some cases, only the data controller or only the processor must designate a data protection officer, while in other cases, both must do so.

192. The question arises as to whether the second defendant falls under one of these 3 cases, such that the obligation to designate a data protection officer rests with it.

193. Given that the second defendant is not a public authority, Article 37.1.a) does not apply to it.

194. Regarding Article 37.1.c) of the GDPR, the Contentious Chamber recalls that three cumulative conditions apply: (i) processing of special categories of data or personal data related to criminal convictions and offenses, (ii) large-scale nature, and (iii) core/main activity.

195. As already established above, the Contentious Chamber agrees with the position of the second defendant that it does not process special categories of personal data within the meaning of Article 9 of the GDPR in the context of the subcontracting agreement concluded with the first defendant. The fact that the second defendant offers the possibility of processing biometric data within the framework of Z does not automatically imply that the second defendant processes biometric data for all its clients. Furthermore, the processing of biometric personal data does not automatically imply that it concerns the processing of a special category of personal data under Article 9 of the GDPR, given that no identification or verification is proven. Therefore, it is not demonstrated that the first condition is met.

196. Regarding the condition related to large-scale nature, the GDPR does not provide any definition. According to Recital 91, it refers to "large-scale processing operations aimed at processing a substantial volume of personal data at the regional, national, or supranational level, which may affect a significant number of data subjects and are likely to result in a high risk [...]." The Contentious Chamber notes that the Inspection Service does not demonstrate that the processing of special categories of personal data is carried out on a large scale. The fact that Z is distributed in 9 European countries does not prove that special categories of personal data within the meaning of Article 9 of the GDPR are processed on a large scale. Finally, regarding the large-scale nature, the Contentious Chamber notes that the revenue of the second defendant generated by Z and involving biometric readers accounted for only 0.93% of the second defendant's revenue in 2021. The Contentious Chamber considers this insufficient to speak of a core activity.

197. Furthermore, the Inspection Service points out that it can also be considered based on Article 37.1.b) of the GDPR that the second defendant is required to designate a data protection officer since the daily recording of workers' arrival and departure times at the workplace constitutes regular and systematic monitoring of data subjects. In this context, the Contentious Chamber agrees with the position of the second defendant that any potential regular and systematic monitoring is carried out by the first defendant in the context of time recording, and not by the second defendant. It indeed only offers storage for encrypted (personal) data.

198. In light of the above, the Contentious Chamber concludes that there is no violation of the obligation, under Article 37.1.b) and c) of the GDPR, to designate a data protection officer.

### III. Corrective Measures

#### III.1. Regarding the First Defendant

##### III.1.1. Identified Violations and Measures Taken by the Contentious Chamber

###### III.1.1.1.

## Identified Violations

199. The Contentious Chamber has identified the following violations. First, the Contentious Chamber found that the first defendant unlawfully processed special categories of personal data in the context of the time recording system and that in this context, it also violated the principles of purpose limitation and data minimization (Article 5.1.a) of the GDPR, Article 9.1, in conjunction with Article 6.1 of the GDPR, Article 9.2 of the GDPR, Article 5.1.b) of the GDPR, Article 5.1.c) of the GDPR).

200. Next, the Contentious Chamber also judged that the welcome brochure did not sufficiently inform the data subjects about the disputed processing.

**\*\*Decision on the Merits 114/2024 – 52/72\*\***

More specifically, the welcome brochure did not generally comply with the obligation set out in Article 12.1 of the GDPR, according to which the data controller must take appropriate measures to ensure that the information referred to in Article 13 of the GDPR is provided in a concise, transparent, understandable, and easily accessible manner, using clear and plain language. In particular, the Contentious Chamber notes that the retention periods (Article 13.2.e of the GDPR), the purposes, and the legal basis (Article 13.1.c of the GDPR) were not adequately included in the welcome brochure. Given that the first defendant illicitly invokes consent based on Article 6.1.a) and Article 9.2.a) of the GDPR, it was also necessary to inform the data subjects that they had the right to withdraw their consent (Article 3.2.c of the GDPR).

Regarding the mention of the possibility to lodge a complaint with the Data Protection Authority (Article 13.2.d of the GDPR), the Contentious Chamber notes that this is also not included in the welcome brochure.

201. Furthermore, the Contentious Chamber found that the first defendant did not provide sufficient information during the second access request, namely information on the duration and modalities of data retention and on data security, which constitutes a violation of the first defendant's obligation to inform the data subject in a comprehensible and easily accessible manner, using clear and plain language, as provided for in Article 15.1.d) in conjunction with Article 12.1 of the GDPR.

202. In addition, the Contentious Chamber believes that several violations have occurred regarding the documentation obligation of the first defendant. Concerning the processing of special categories of personal data in the context of time recording, the first defendant did not conduct a DPIA before commencing the disputed processing activities (Article 35 of the GDPR).

203. The first defendant also failed to mention the identity of the data protection officer in the register of processing activities (Article 30.1.a) of the GDPR). The first defendant also violated Article 30.1.b) and c) of the GDPR by not mentioning in the register of processing activities all the purposes and categories of personal data in the context of time recording, as outlined in the 2022 version of the work regulations. Finally, the Contentious Chamber notes that the second defendant, in its capacity as a processor within the biometric time recording system, is not mentioned as a recipient in the register of processing activities (Article 30.1.d) of the GDPR).

204. Finally, in light of the aforementioned violations, the Contentious Chamber found that the first defendant has violated the principle of accountability as defined in Article 5.2 of the GDPR.

**\*\*Decision on the Merits 114/2024 – 53/72\*\***

**\*\*III.1.1.2.\*\***

**\*\*Measures Taken by the Contentious Chamber\*\***

205. Under Article 100 of the LCA, the Contentious Chamber has the power to:

- 1° dismiss the complaint;
- 2° order a dismissal;
- 3° pronounce a suspension of the ruling;
- 4° propose a settlement;
- 5° issue warnings and reprimands;
- 6° order compliance with the requests of the data subject to exercise their rights;
- 7° order that the data subject be informed of the security issue;
- 8° order the freezing, limitation, or temporary or permanent prohibition of processing;
- 9° order compliance with the processing;



10° order the rectification, restriction, or erasure of data and notification of such to the data recipients;  
11° order the withdrawal of the accreditation of certification bodies;  
12° impose fines;  
13° impose administrative fines;  
14° order the suspension of cross-border data flows to another State or an international organization;  
15° refer the case to the public prosecutor of the Brussels Crown, who will inform it of the follow-up given to the case;  
16° decide on a case-by-case basis to publish its decisions on the website of the Data Protection Authority.

206. Regarding the aforementioned violations concerning the documentation obligation under Articles 30.1.a), b), c), and d) of the GDPR and Article 35 of the GDPR, the Contentious Chamber decides to issue a reprimand based on Article 100, 5° of the LCA. The importance of conducting a DPIA under Article 35 of the GDPR cannot be underestimated. The obligation to conduct a DPIA aims to describe the process of processing personal data to identify not only the necessity and proportionality of the processing but also the risks to the rights and freedoms of the data subjects during the processing of personal data. Failing to conduct a DPIA constitutes (therefore) a violation of the GDPR in itself, while increasing the risk of further violations of the GDPR because the risks of potential (other) violations of the GDPR are not detected in time.

207. Regarding the obligation to maintain a register of processing activities under Article 30 of the GDPR, the Contentious Chamber emphasizes that in order to effectively apply the obligations contained in the GDPR, it is essential that the data controller...

Decision on the merits 114/2024 – 54/72

processing and subcontractors maintain a complete and accurate overview of the processing of personal data they carry out. This register of processing activities thus primarily serves as a tool to assist the data controller or the processor in complying with the GDPR for the various data processing activities they perform, as the register makes the main characteristics of these processes visible. The Contentious Chamber considers that this register of processing activities is an essential instrument within the framework of the principle of accountability (already mentioned in Article 5.2 and Article 24 of the GDPR) and that this register underpins all obligations imposed by the GDPR on the data controller and the processor. It is therefore of the utmost importance that it is complete and accurate.

208. The Contentious Chamber finds that there are sufficient elements to issue a reprimand for violations of Article 5.2, Article 30, and Article 35 of the GDPR, which constitutes a mild and sufficient sanction in light of the GDPR violations identified in this case. In determining the sanction, the Contentious Chamber takes into account the fact that the first defendant has already taken several measures to comply with its obligations as prescribed by the GDPR and provides evidence of this.

209. Regarding the violation due to the incomplete response to the second access request (under Article 15.1.d) and Article 12.1 of the GDPR), the Contentious Chamber warns the first defendant for the future, based on Article 100, 5° of the LCA, on the one hand, that the fact that the personal data of the data subject is no longer processed by the data controller does not mean that the right of access should no longer be executed, and on the other hand, that if the requested information is not included in the enumeration provided in Article 15.1 of the GDPR, this does not mean that no response should be given to an access request, given that the obligation to provide information in a concise, transparent, comprehensible, and easily accessible manner also pertains to the information obligation referred to in Article 13 of the GDPR. The fact that this information is requested in the context of an access request does not mean that no follow-up should be given to this request for information. The Contentious Chamber believes that a warning is sufficient, as it is not accurate that the first defendant has completely prevented the complainant from exercising their right of access. On the contrary, the first defendant had already responded to the complainant's first access request, a response that was partially included in its response to the complainant's second access request.

210. Regarding the violations of Article 5.1.a) of the GDPR, Article 6.1 of the GDPR, Article 9.1 and 9.2 of the GDPR, Article 5.1.b) of the GDPR, Article 5.1.c) of the GDPR relating to the principles of lawfulness, purpose limitation, and data minimization, and the violation of Article 13.1.c), Article 13.2.c), 13.2.d), and 13.2.e) of the GDPR relating to the information obligation, the Contentious

Chamber decides to impose an administrative fine under the powers conferred by Article 83 of the GDPR and Article 100, § 1, 13° of the LCA.

#### III.1.1.3.

##### Calculation of the fine

211. The EDPB adopted on May 24, 2023, the Guidelines 04/2022 on the calculation of administrative fines under the GDPR<sup>32</sup> (hereinafter: the Guidelines). The Guidelines are immediately applicable as they do not provide for a transitional provision for procedures that were already underway at the time of the adoption of the Guidelines. The Contentious Chamber will therefore apply these Guidelines to the present case.

212. The Guidelines describe a methodology for determining the amount of the fine as follows:

Step 1: identify the processing activities and violations that need to be assessed;

Step 2: set the starting amount for calculating the fine for the identified violations (starting amount);

Step 3: assess the aggravating and mitigating circumstances that may require adjustment of the amount set in Step 2;

Step 4: determine the maximum amounts applicable for the violations and whether any increases from the previous step do not exceed these amounts;

Step 5: determine whether the final amount of the calculated fine is effective, proportionate, and dissuasive, and adjust this amount to these criteria if necessary.

213. The Contentious Chamber will determine the amount of the administrative fine using this methodology.

#### III.1.1.4.

Step 1: identify the processing activities and violations that need to be assessed;

214. In order to determine the starting amount of the fine, it is first necessary, as described in the Guidelines, to examine whether there is one or more behaviors that may be subject to sanction. The Contentious Chamber found that the first defendant unlawfully processed special categories of personal data within the framework of the time registration system and that in this context, it also violated the principles of purpose limitation and data minimization.

32 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR (V2.1, May 24, 2023), available via the following link: [https://www.edpb.europa.eu/system/files/2024-01/edpb\\_guidelines\\_042022\\_calculationofadministrativefines\\_fr\\_0.pdf](https://www.edpb.europa.eu/system/files/2024-01/edpb_guidelines_042022_calculationofadministrativefines_fr_0.pdf).

Decision on the merits 114/2024 – 56/72

(article 5.1.a) of the GDPR, article 6.1 of the GDPR, article 9.2 of the GDPR, article 5.1.b) of the GDPR, article 5.1.c) of the GDPR).

215. The Dispute Chamber also found that the welcome brochure did not sufficiently inform the data subjects about the disputed processing.

More specifically, the welcome brochure did not contain enough information, among other things, about retention periods (article 13.2.e) of the GDPR), purposes, and the legal basis (article 13.1.c) of the GDPR). The Dispute Chamber believes that these elements were not (sufficiently) included in the welcome brochure. Given that the first defendant illicitly invokes consent based on article 6.1.a) and article 9.2.a) of the GDPR, it was also necessary to inform the data subjects that they had the right to withdraw their consent (article 13.2.c) of the GDPR). Regarding the mention of the possibility to file a complaint with the Data Protection Authority (DPA) (article 13.2.d) of the GDPR), the Dispute Chamber notes that this is also not included in the welcome brochure.

216. The Dispute Chamber considers that this constitutes a single sanctionable behavior. In this context, the Dispute Chamber refers to the Guidelines which specify that when assessing "[the] same processing operation or [related] processing operations," it should be kept in mind that all necessary legal obligations for the processing operations to be carried out in compliance with the law can be taken into account by the supervisory authority in its assessment of violations, including [...] transparency obligations (e.g., article 13 of the GDPR). This point is also highlighted by the terms "in the context of the same processing operation or related processing operations," which indicate that the scope of this provision encompasses any violation related to the same processing operations or

related processing operations that may impact them. The Dispute Chamber finds that the violations established above concerning the principles of lawfulness, purpose limitation, data minimization, information obligation, and accountability are related to the same processing activity, namely the time recording system using fingerprints. Therefore, the Dispute Chamber believes that the circumstances constitute a single behavior that will result in the imposition of a single fine for the violations arising from the behavior in question.

#### III.1.1.5.

##### Step 2: Set the starting amount

33 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR (V2.1, May 24, 2023), p. 13,  
[https://edpb.europa.eu/system/files/2024-01/edpb\\_guidelines\\_042022\\_calculationofadministrativefines\\_fr\\_0.pdf](https://edpb.europa.eu/system/files/2024-01/edpb_guidelines_042022_calculationofadministrativefines_fr_0.pdf).

##### Decision on the merits 114/2024 – 57/72

217. As described in the Guidelines, the starting amount of the fine should then be set. This starting amount constitutes the baseline for further calculations in the subsequent steps, where all relevant facts and circumstances are taken into account. The Guidelines indicate that the starting amount is determined using three elements: i) the qualification of the violations under Article 83, paragraphs 4 to 6 of the GDPR (step 2.1); ii) the severity of the violation (step 2.2); and iii) the turnover of the company (step 2.3).

#### III.1.1.5.1.

##### Step 2.1: Qualification of violations under Article 83, paragraphs 4 to 6 of the GDPR

218. As mentioned in the Guidelines, almost all obligations of the data controller are qualified in the provisions of Article 83, paragraphs 4 to 6 of the GDPR. The GDPR distinguishes between two types of violations. On the one hand, there are violations subject to penalties under Article 83.4 of the GDPR, which are liable to a maximum fine of 10 million euros (or, in the case of a company, 2% of the annual turnover, with the higher amount being retained); on the other hand, there are violations subject to penalties under Article 83, paragraphs 5 and 6 of the GDPR, which are liable to a maximum fine of 20 million euros (or, in the case of a company, 4% of the annual turnover, with the higher amount being retained). By this distinction, the legislator has provided an initial indication in abstracto of the severity of the violation: the more severe the violation, the higher the fine.

219. For the violations in question of Article 5.1.a) of the GDPR, Article 6.1 of the GDPR, Article 9.1 and 9.2 of the GDPR, Article 5.1.b) of the GDPR, Article 5.1.c) of the GDPR, Article 13.1.c), 13.2.c), d) and e) of the GDPR in conjunction with Article 12.1 of the GDPR, an administrative fine of up to 20 million euros may be imposed, or in the case of a company, 4% of the global annual turnover, with the higher amount being retained (Article 83.5 of the GDPR). It follows from this qualification that violations of these provisions are considered serious by the legislator.

#### III.1.1.5.2.

##### Severity of the violations in the present case

220. In order to determine the severity of the violation, the Guidelines provide that account should be taken of the nature, severity, and duration of the violation, as well as the intentional or negligent character of the violation and the categories of personal data concerned.

221. Nature of the violation - The Guidelines provide that the supervisory authority may consider the interest that the breached provision aims to protect and the importance of this provision within the framework of data protection. Regarding lawfulness, the GDPR states that there are six bases for lawful processing of personal data.

##### Decision on the merits 114/2024 – 58/72

When engaging in activities that involve the processing of personal data, the data controller must always take the time to consider what the appropriate legal basis for the intended processing would be. The applicable legal basis also influences the applicable rights of the data subjects or the applicable information obligations. Violations of these fundamental principles thus constitute serious breaches, subject to the highest administrative fines provided for by the GDPR. Consequently, the Contentious Chamber concludes that legality occupies a central place in the framework of data

protection and therefore justifies the imposition of a fine.

222. Nature, severity, and duration of the violation (Article 83.2.a) of the GDPR) - Regarding the severity of the violation, the Contentious Chamber observes that the principle of legality (Article 5.1.a) and Article 6 of the GDPR), together with the principles of purpose limitation (Article 5.1.b) of the GDPR) and data minimization (Article 5.1.c) of the GDPR) are fundamental principles of the protection guaranteed by the GDPR. Furthermore, the data controller should provide the data subject with the necessary information to ensure fair and transparent processing, taking into account the particular circumstances and context in which the personal data is processed.

223. Regarding the nature of the processing, the Contentious Chamber observes that a valid legal basis and transparent information are key elements of the fundamental right to data protection. Violations of these fundamental principles thus constitute serious breaches, subject to the highest administrative fines provided for by the GDPR.

224. In its response to the sanction form, the first defendant does not contest the severity of the violation but emphasizes that this severity should be assessed in light of all the circumstances below, specific to this case. It highlights that the nature of the processing did not present a high risk because the system implemented by the second defendant only allowed for associating a code with sensitive data, with the digital fingerprint remaining in the hardware. Therefore, the processing of sensitive data only allowed for the creation of a code that was then associated with the individual worker's file, where only the hours worked were recorded. The sensitive data is neither reproduced, nor communicated, nor analyzed. Only the clocking hours are recorded and associated with a code, the fingerprint remains in the hardware of the second defendant which, as noted by the first defendant, does not seem to be criticized by the Contentious Chamber. The Contentious Chamber takes these circumstances into account at step 3 when assessing any potential circumstances.

34EDPB - Guidelines 5/2020 on consent under Regulation 2016/679 (May 5, 2020), p. 5

[https://www.edpb.europa.eu/sites/default/files/files/file1/edpb\\_guidelines\\_202005\\_consent\\_fr.pdf](https://www.edpb.europa.eu/sites/default/files/files/file1/edpb_guidelines_202005_consent_fr.pdf).

Decision on the Merits 114/2024 – 59/72

aggravating or mitigating factors, as prescribed by the Guidelines.<sup>35</sup> In accordance with the Guidelines, each criterion of Article 83.2 of the GDPR can only be taken into account once.

225. Regarding the purpose of the processing, the Contentious Chamber notes that the processing aimed to record the working hours of workers and to calculate and pay wages based on this. As also indicated, no payment could be made if no timekeeping was recorded, which allowed for measures with negative consequences to be taken. In accordance with the Guidelines, the Contentious Chamber gives more weight to this factor considering the relationship between the data subjects as workers and the first defendant as employer.<sup>36</sup>

226. In its response to the sanction form, the first defendant states that it is active in the production of lightweight metal packaging products (aluminum cans). In this capacity, it only processes data related to working hours, obtained through biometric clocking in and out. Sensitive data remains secured and stored in the system of the second defendant. The periphery of the main activity is therefore limited to the calculation of wages, based on the recording of working time.

227. However, the Contentious Chamber observes that the stated purpose of the disputed processing could also have been achieved without processing the personal biometric data in question. The processing of personal data does not constitute a core activity of the first defendant, but nonetheless constitutes an important ancillary activity in the performance of its main task. The Contentious Chamber places significant weight on this factor.

228. Regarding the severity of the violation, the Contentious Chamber considers that the unlawful processing in the context of the time recording in question applied to all workers. The same applies to the obligation to inform workers, at least until the adoption of the 2022 work regulation. Subsequently, to assess the severity of the violation, the Contentious Chamber does take into account the aforementioned violations committed. However, it is not established that the first defendant completely failed to meet its obligations under the GDPR. The first defendant unlawfully invoked consent as the legal basis for the disputed processing. Although the Contentious Chamber found several violations of the obligation to inform regarding the disputed processing, it cannot be said that the

35 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR (V2.1, May 24, 2023), p. 29.

36 EDPB - Guidelines 5/2020 on consent under Regulation 2016/679 (May 5, 2020), p. 20  
[https://www.edpb.europa.eu/sites/default/files/files/file1/edpb\\_guidelines\\_202005\\_consent\\_fr.pdf](https://www.edpb.europa.eu/sites/default/files/files/file1/edpb_guidelines_202005_consent_fr.pdf).

Decision on the merits 114/2024 – 60/72

the first defendant completely failed to inform its workers about the processing in question.

Furthermore, it does not appear that the workers suffered substantial harm as a result of the disputed processing and the failure to fulfill the obligation to inform. The Contentious Chamber assigns a light weight to this factor.

229. Regarding the duration, it was found that the disputed time recording system was introduced on March 16, 2020, and was interrupted following the inspection report at the end of 2022, which constitutes a relatively short period. Concerning the duration of the violation, the first defendant states in its response to the sanction form that it is a relatively young company that made a mistake in the time recording system. It adds that it immediately terminated the time recording system. The Contentious Chamber assigns a light weight to this factor.

230. Regarding the scope of the processing, the first defendant argues that the sensitive data in question, namely fingerprints, remain locked and secured in the hardware system of the second defendant. The scope of the processing is therefore very local and shows that the risk is very low, if not nonexistent, given that the sensitive data remain in the system of the second defendant, which is secured and locked. The first defendant itself does not have the fingerprint but only the encrypted code related to the fingerprint and the time recording data. The first defendant notes that this code itself is generated by the equipment of the second defendant and that the encryption key is not known to the first defendant, should it wish to obtain the fingerprint as such. The extent of the local processing did not allow for the exclusion of any association between the code and the fingerprints stored in the hardware of the second defendant, so the risk of dissemination was very low. The Contentious Chamber takes these circumstances into account at step 3 when assessing any aggravating or mitigating circumstances, as prescribed by the Guidelines.<sup>37</sup> According to the Guidelines, each criterion of Article 83.2 of the GDPR can only be considered once.

231. Negligent or deliberate nature of the violation (Article 83.2.b of the GDPR) — The Contentious Chamber recalls that, in general, "intention" includes both knowledge and will regarding the characteristics of an offense, while the terms "not deliberately" mean that there was no intention to cause the violation, although the data controller or the processor violated the duty of care prescribed by the legislation.<sup>38</sup> In other words, two cumulative elements are necessary for a

37 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR (V2.1, May 24, 2023), p. 29.

38 Article 29 Working Party on Data Protection - Guidelines on the application and setting of administrative fines for the purposes of Regulation (EU) 2016/679 (WP 253, October 3, 2017), p. 12.  
Decision on the merits 114/2024 – 61/72

violation should be considered intentional, namely the knowledge of the violation and the will in relation to this act.<sup>39</sup>

232. Regarding the intentional component, the Contentious Chamber also recalls that the Court of Justice has set a high threshold for an act to be considered intentional. The Court of Justice has thus held in criminal cases that it is a matter of "gross negligence" rather than "intent" when "the responsible person characteristically violates the duty of care that they should have and could have observed given their qualities, knowledge, skills, and individual situation."<sup>40</sup> Even if one can expect a company whose processing of personal data is not its main activity to take sufficient measures to protect personal data and to fully recognize its obligations in this regard, such a qualified violation does not necessarily demonstrate that it is a deliberate violation.<sup>41</sup>

233. In other words, this means that a data controller can also be sanctioned by an administrative fine under Article 83 of the GDPR for behavior falling within

the scope of the GDPR, when this data controller could not ignore that their behavior constituted a violation, regardless of whether they were aware or not that they were violating the provisions of the GDPR.<sup>42</sup> According to the Contentious Chamber, there is no - manifest - intention on the part of the second defendant to deliberately violate the GDPR in the context of the introduction of the time recording system using biometric data, nor in the context of the failure to fulfill the information obligation. The Contentious Chamber, on the other hand, finds that there was negligence in the commission of the violations. The identified violations are due to a misjudgment by the first defendant. They took fraud prevention as a starting point in the context of time recording, which constitutes a legitimate purpose, but in this regard, the defendant party should also have assessed compliance with the GDPR. One can expect a professional such as the first defendant, particularly given the specific nature of the personal data.

39 See also EDPB - Binding Decision 1/2023 on the dispute submitted by the Irish SA on data transfers by Meta

Platforms Ireland Ltd (Facebook), point 103, available via the following link:

<https://www.edpb.europa.eu/our-work-tools/our-documents/binding-decision-board-art-65/binding-decision-12023-dispute-submitted-fr>.

40 CJEU, June 3, 2008, C-308/06, Intertanko et al. (ECLI:EU:C:2008:312), point 77.

41 See also EDPB – Binding Decision 2/2022 on the dispute arisen on the draft decision of the Irish Supervisory

Authority regarding Meta Platforms Ireland Limited (Instagram) under Article 65(1)(a) GDPR, July 28, 2022, point 204.

42 CJEU, December 5, 2023, C-807/21, Deutsche Wohnen SE v. Staatsanwaltschaft Berlin (ECLI:EU:C:2023:950), point 76.

See also CJEU, June 18, 2013, C-681/11, Schenker & Co. et al. (ECLI:EU:C:2013:404), point 37; CJEU, March 25, 2021,

Lundbeck v. Commission, C-591/16 P (ECLI:EU:C:2021:243), point 156; and CJEU March 25, 2021, C-601/16 P, Arrow Group and

Arrow Generics v. Commission (ECLI:EU:C:2021:244), point 97.

Decision on the merits 114/2024 – 62/72

staff, that it is fully aware of the applicable standards and that it complies with them.

234. In its response to the sanction form, the first defendant aligns with the position of the Contentious Chamber and recalls that it sought to introduce a fraud prevention system related to working hours, this issue being indeed present and demonstrated in the context of the current proceedings. The first defendant acknowledges that it should have used another system for recording working time.

235. The Contentious Chamber recognizes the necessity for the first defendant to address and/or prevent potential fraud and assigns moderate weight to this factor.

236. Categories of personal data concerned by the violation (Article 83.2.g of the GDPR) - The Guidelines emphasize that the GDPR clearly identifies the types of data that require special protection and for which fines should therefore be more severe. In any case, this concerns the types of data referred to in Articles 9 and 10 of the GDPR. Generally, the more numerous these categories of data are or the more sensitive the data, the more weight the supervisory authority can assign to this factor.<sup>43</sup> The Contentious Chamber has classified the personal data processed by the first defendant as special under Article 9 of the GDPR. The identified violations regarding lawfulness and the obligation to inform also concern personal data under Article 9 of the GDPR, which is why the Contentious Chamber assigns more weight to this factor.

III.1.1.5.3.

Company turnover

237. The Contentious Chamber specifies in this regard that at the time of sending the sanction form dated June 4, 2024, it did not yet have the turnover figures for the year 2023 and therefore had to take into account the turnover figures for the year 2022. After the sending of the sanction form, the annual

accounts for the 2023 financial year were published on the website of the National Bank of Belgium, where a turnover of 85,444,466 euros was recorded.

i.

Conclusion regarding the starting amount

a. Theoretical starting amount (based on the severity of the violation)

238. Under Article 83.5 of the GDPR, the fine amounts to a maximum of 20 million euros or, in the case of a company, up to 4% of the total global annual turnover of the previous financial year, with the higher amount being retained, which is not the case here. The maximum legal amount therefore stands at 20 million euros.

43 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR (V2.1, May 24, 2023), p. 22,

[https://edpb.europa.eu/system/files/2024-01/edpb\\_guidelines\\_042022\\_calculationofadministrativefines\\_fr\\_0.pdf](https://edpb.europa.eu/system/files/2024-01/edpb_guidelines_042022_calculationofadministrativefines_fr_0.pdf).

Decision on the merits 114/2024 – 63/72

239. Based on the assessment of the criteria outlined above, the Disciplinary Chamber must determine whether the violation is deemed to be of low, medium, or high severity. These categories do not affect the question of whether a fine can be imposed or not.<sup>44</sup>

240. This assessment is not a mathematical calculation in which the aforementioned factors are considered separately, but rather a thorough evaluation of the specific circumstances of the case, all the aforementioned factors being interrelated. This is why, when assessing the severity of the violation, the violation must be considered as a whole.<sup>45</sup>

- When calculating the administrative fine to be imposed for violations of low severity, the supervisory authority sets a starting amount for the subsequent calculation between 0 and 10% of the applicable legal maximum.
- When calculating the administrative fine to be imposed for violations of medium severity, the supervisory authority sets a starting amount for the subsequent calculation between 10 and 20% of the applicable legal maximum.
- For violations of high severity, when calculating the administrative fine, the supervisory authority sets a starting amount for the subsequent calculation between 20 and 100% of the applicable legal maximum.<sup>46</sup>

241. In general, the more severe the violation in the relevant category, the higher the starting amount is likely to be.<sup>47</sup>

242. In her response to the sanction form, the first defendant indicates that, considering the above criteria, the degree of severity of the violation could be considered low. She refers in this regard to the elements examined above such as the nature of the processing, the scope of the processing, the purpose of the processing, the extent of the harm, and the duration of the violation.

243. The Disciplinary Chamber found that there was a violation of Article 5.1(a), (b), and (c) of the GDPR, Article 9.1 in conjunction with Articles 6.1 and 9.2 of the GDPR, on the one hand, and a violation of Article 13.1(c) and 13.2(c), (d), and (e) of the GDPR in conjunction with Article 12.1, on the other hand, which are included in the violations of Article 83.5 of the GDPR. Subsequently, the Disciplinary Chamber conducted an analysis of the nature of the violation, its purpose, the extent and duration of the processing, as well as the categories of personal data processed and the negligent nature of the violation.<sup>48</sup>

44 EDPB, Guidelines 04/2022 on the calculation of administrative fines under the GDPR V2.1, May 24, 2023, p. 23, [https://edpb.europa.eu/system/files/2024-01/edpb\\_guidelines\\_042022\\_calculationofadministrativefines\\_fr\\_0.pdf](https://edpb.europa.eu/system/files/2024-01/edpb_guidelines_042022_calculationofadministrativefines_fr_0.pdf).

45 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR V2.1, May 24, 2023, p. 23, [https://edpb.europa.eu/system/files/2024-01/edpb\\_guidelines\\_042022\\_calculationofadministrativefines\\_fr\\_0.pdf](https://edpb.europa.eu/system/files/2024-01/edpb_guidelines_042022_calculationofadministrativefines_fr_0.pdf).

46 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR (V2.1, May 24, 2023), p. 23

47 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR (V2.1, May

24, 2023), p. 23

48 See points 95 to 102 inclusive of this decision.

Decision on the merits 114/2024 – 64/72

244. Based on the previous assessments of the aforementioned circumstances, the Dispute Chamber considers that the behavior falling under Article 83.5 of the GDPR is, in itself, of medium severity. In this regard, the Dispute Chamber takes into account, on the one hand, notably the sensitive nature of biometric personal data and their characteristics, the professional capacity of the first defendant as an employer in relation to the complainant, and the broad scope, given that the time recording system applies to all workers.

245. On the other hand, the Dispute Chamber also considers the relatively limited duration of the violation, the unintentional nature of the negligence on the part of the first defendant, and the fact that they informed the affected individuals, albeit incompletely, about the disputed processing.

246. Therefore, the starting amount for the subsequent calculation must be set at an amount between 10% and 20% of the applicable legal maximum. The Dispute Chamber decides to set a theoretical starting amount of 2 million euros per violation, which is 10% of the applicable legal maximum amount of 20 million euros (Article 83.5 of the GDPR).

b. Adjustment of the starting amount based on the size of the company

247. Next, the Dispute Chamber must verify whether the starting amount should be adjusted based on the size of the company. This adjustment is only valid for companies to which the static legal limit applies, namely when the company has generated a turnover of less than 500 million euros in the previous financial year. Since this is the case here, the fine must be adjusted according to the static legal limit.

248. The Dispute Chamber has already explained that the behavior observed above falls under Article 83.5 of the GDPR and is of medium severity. For violations mentioned in Article 83.5 of the GDPR, of medium severity, applied to a company with a turnover between 50 million euros and 100 million euros, the fine amounts to 8% to 20% of the starting amount, with the fine not being less than 160,000 euros nor exceeding 800,000 euros.<sup>49</sup>

249. Considering the minimum and maximum amounts set in the Guidelines by level, on the one hand, and the relevant turnover of the data controller, on the other hand, the Dispute Chamber decides to reduce the final starting amount for each of the identified violations (falling under Article 83.5 of the GDPR with medium severity) to reach an adjusted starting amount of 160,000 euros, which is 8% of the theoretical starting amount of 2 million euros.

49 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR (V2.1, May 24, 2023), p. 52.

Decision on the Merits 114/2024 – 65/72

III.1.1.6.

Step 3: Assessment of Aggravating and Mitigating Circumstances

i)

Assessment of the Application of Possible Aggravating or Mitigating Circumstances

250. As mentioned in the guidelines, it is necessary to assess whether, in the circumstances of the case at hand, it is appropriate to set a fine that is higher or lower than the starting amount defined in this regard. The circumstances to be taken into account are set out in Article 83.2, ab initio and points a) to k) inclusive of the GDPR. Each of the circumstances mentioned in this provision can only be assessed once. In the previous step, account has already been taken of the nature, seriousness, and duration of the infringement, the intentional or negligent nature of the infringement, and the categories of personal data. Therefore, the remaining parts are c) to f) inclusive and h) to k) inclusive.

251. Measures Taken to Mitigate the Damage Suffered by the Data Subjects (Article 83.2.c) of the GDPR) – As indicated in the WP 253 Guidelines of the Group 2954, data controllers and processors are already required "to implement technical and organizational measures to ensure a level of security appropriate to the risk, to carry out data protection impact assessments, and to mitigate risks to the rights and freedoms of individuals resulting from the processing of personal data." In the event of a breach, the data controller or processor must therefore do "everything in their power" to reduce the



consequences of the breach for the affected individual(s). In this case, the first defendant should have refrained from processing the biometric data of its workers. By doing so anyway, the first defendant violated the essence of this obligation. Given that the workers of the first defendant were insufficiently informed about the processing and it is not established that they provided (freely) their explicit consent, the first defendant committed a violation of the personal data protection of its workers by carrying out this processing.

252. The extent to which the data controller or processor is liable in light of the technical and organizational measures it has implemented in accordance with Articles 25 and 32 of the GDPR (Article 83.2.c) of the GDPR) – In section II.8, the Litigation Chamber found that the first defendant took various organizational measures to secure the personal data in question. Furthermore, the first defendant engaged the second defendant regarding the

50 EDPB - Guidelines 04/2022 on the Calculation of Administrative Fines under the GDPR (V2.1, May 24, 2023), p. 23.

51 See points 95-98 of this decision.

52 See points 99-101 of this decision.

53 See point 102 of this decision.

54 Article 29 Working Party on Data Protection – Guidelines on the Application and Setting of Administrative Fines for the purposes of Regulation (EU) 2016/679 (October 3, 2017).

Decision on the merits 114/2024 – 66/72

technical security of personal data. The Contentious Chamber has found in points II.7 and II.8 that there was no violation of Article 32 of the GDPR. Therefore, the Contentious Chamber takes into account the fact that the first defendant has indeed expressed the intention to adequately protect the specific personal data processed and has also concluded a subcontracting agreement with the second defendant for this purpose. In this regard, the Contentious Chamber particularly notes that the fingerprints themselves did not leave the secure environment of the second defendant and that the first defendant only had a code that could be associated with time recording, which is considered a mitigating circumstance.

253. Relevant violation previously committed by the data controller or the processor (Article 83.2.e of the GDPR) – The Contentious Chamber takes into account the fact that to date, it has not been seized of any other proceedings against the first defendant. In accordance with the Guidelines, this factor should therefore be considered neutral.

254. The manner in which the supervisory authority became aware of the violation (Article 83.2.h) – Given that the Contentious Chamber became aware of the violation following a complaint, this element is deemed neutral in accordance with the Guidelines.

255. The degree of cooperation established with the supervisory authority in order to remedy the violation and mitigate any potential negative effects (Article 83.2.f of the GDPR) — The Contentious Chamber notes that the second defendant has been cooperative towards it. In accordance with the Guidelines, the Contentious Chamber considers the ordinary obligation of cooperation to be neutral, given the general obligation of cooperation set out in Article 31 of the GDPR.

256. In its response to the sanction form, the first defendant emphasizes that not only did it fully cooperate, but it also immediately ceased using the biometric time recording system without waiting for a decision from the Contentious Chamber. This helped to reduce the duration of the violation, which could have extended throughout the entire procedure.

257. The Contentious Chamber acknowledges that the first defendant immediately ceased using the biometric time recording system but emphasizes that it has already taken this into account in the assessment of the duration of the violation (see above). In accordance with the Guidelines, each criterion of Article 83.2 of the GDPR cannot be

55 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR (V2.1, May 24, 2023), p. 32.

56 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR (V2.1, May 24, 2023), p. 33.

Decision on the merits 114/2024 – 67/72

considered only once in the context of the overall assessment of the article in question.<sup>57</sup>

258. Any other aggravating or mitigating circumstances applicable to the circumstances of the case (Article 82.3.k) of the GDPR) - The Contentious Chamber takes into account the fact that no financial profit arises from the processing in question for the first defendant, which the Contentious Chamber considers as a mitigating circumstance when determining the amount of the fine. The Contentious Chamber also noted as another circumstance the long delay between the finalization of the investigation report and the hearing on the one hand and (the publication of) this decision on the other hand. This element was considered as a mitigating circumstance regarding the amount of the fine.

259. The first defendant observes that its turnover has been taken into account to determine the level of the fine in the sanction form. However, it draws attention to the fact that the company has not made any profits since its creation in 2019, but is even recording losses due to the nature of its investments. In drafting the response to the sanction form, the first defendant emphasizes that the annual accounts for 2023 were not yet finalized, but that the financial outlook was not positive. Consequently, it had to carry out a series of layoffs for economic reasons at the end of 2023 and the beginning of 2024. The first defendant specifies that its turnover is very high, given the nature of its investments and activities, namely wholesale sales to professionals. In contrast, its profits are modest, even negative considering the economic situation. The first defendant claims that it has not yet achieved the results it aimed for when it launched its activities in Belgium. Furthermore, it generates a significant number of jobs in Flanders, some of which could be threatened by the proposed fine of 90,000 euros.

260. The Contentious Chamber emphasizes that, in accordance with the EDPB guidelines, it is required to calculate the amount of the proposed fine based on the turnover of the previous financial year, with no derogation from this calculation method being provided. The Contentious Chamber acknowledges, however, that the difficult economic environment and the fact that the proposed fine would jeopardize a significant number of jobs are mitigating factors in this case. In this regard, the Contentious Chamber particularly takes into account the fact that the first defendant acknowledged the violation from the outset of the procedure and has assumed responsibility in this matter throughout the present procedure.

57 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR (V2.1, May 24, 2023), p. 29.

Decision on the merits 114/2024 – 68/72

261. Other mitigating or aggravating circumstances – Other circumstances do not apply in this case because the circumstances referred to do not arise in this instance.

ii)

Influence on the amount of the fine

262. Above, the concrete starting amount was set at 160,000 euros. Subsequently, any possible mitigating or aggravating circumstances were examined. The Disciplinary Chamber considered that several mitigating circumstances could be taken into account. Therefore, the fine indicated in the sanction form was adjusted to 90,000 euros.

263. Following the elements outlined above, including the arguments put forward by the first defendant in their response to the sanction form, the Disciplinary Chamber decided to reduce the proposed fine from 90,000 euros to 45,000 euros.

III.1.1.7.

Step 4: Verification of exceeding maximum amounts

264. As previously stated, a maximum fine of 4% of the annual global turnover of the company applies to the established violation. Given the gross margin of the first defendant (85,444,466 euros), the legal maximum fine to be imposed amounts to 3,417,778.64 euros. The amount of the fine determined in the sanction form for the established violations was set at 90,000 euros, which is below the legal maximum amount. The reduced fine amount of 45,000 euros is also well below the aforementioned legal maximum, so there is no exceeding of this maximum.

III.1.1.8.

Step 5: Assessment of the effectiveness, proportionality, and deterrent effect

265. Regarding the disproportionate nature of the proposed fine, in their response to the sanction form,

the first defendant refers to previous decisions of the Disciplinary Chamber concerning the processing of biometric data, notably those regarding the use of thermal cameras at Brussels-Zaventem and Charleroi airports. The first defendant claims that the fines imposed by the Disciplinary Chamber were considered disproportionate by the Market Court. According to the first defendant, it is clear that the two judgments in the aforementioned cases are applicable to the present case since they concern the unlawful processing of biometric data. The first defendant believes that the following points are particularly important: (i) the first defendant does not engage in marketing advertising, unlike the airports in the aforementioned cases, and it does not process personal data in the context of its main activity, (ii) the first defendant has never recorded the fingerprint as such since it remained within the system of the second defendant and only received a code to generate information related to working hours, which is fundamentally...

Decision on the merits 114/2024 – 69/72

different from the method used at Brussels Airport, and (iii) the revenue of the first defendant is significantly lower than that of the airports in Brussels and Charleroi.

In light of these circumstances, the proposed amount of 90,000 euros would be disproportionate, according to the first defendant.

266. The Litigation Chamber first recalls that, in accordance with Article 83.2 of the GDPR as well as the Guidelines of Article 29 Working Party and the Guidelines of the EDPB on the matter, fines are imposed "based on the circumstances of the specific case."

Furthermore, the Litigation Chamber emphasizes in this regard the case law of the Brussels Court of Appeal, Market Court section, which states that "the Belgian legal system [does not attribute] binding precedent value to either administrative decisions or judicial decisions. Any decision by a judge (and the same applies to any decision by an administrative authority, as long as the principle of equality is not violated) is specific and does not apply to any case other than the one being dealt with."<sup>58</sup>

Regarding the amount of the administrative fine imposed, the Market Court has also highlighted the discretion of the Litigation Chamber: "This means in practice that the DPA can not only decide not to impose a fine on the offender but also, if it decides to impose a fine, to set it between the minimum, which is 1 EUR, and the maximum provided. The fine imposed is decided by the DPA taking into account the criteria set out in Article 83, paragraph 2 of the GDPR" [The quotes from the Market Court have been freely translated by the General Secretariat of the Authority, in the absence of an official translation].

The Litigation Chamber is therefore not bound by the amounts of fines it has already imposed in previous cases.

267. Next, the Litigation Chamber refers to the fact that the EDPB has published Guidelines on the calculation of administrative fines, which were not yet available when the aforementioned decisions regarding thermal cameras in airports were made. These guidelines specify the calculation of these fines using various factors to be taken into account by the Litigation Chamber. Therefore, the calculation of the administrative fine prior to the publication of the EDPB Guidelines cannot be compared to the calculation of the administrative fine based on these Guidelines.

268. Under Article 83.5, ab initio and under b) of the GDPR, the Litigation Chamber can impose an administrative fine for the violations described above. As described in the Guidelines, the imposition of a fine can be considered effective if it achieves the objectives for which it was imposed. The Litigation Chamber notes that the objective is twofold: to sanction unlawful behavior, on the one hand, and to promote compliance with the applicable regulations, on the other hand. The Litigation Chamber believes that the requirement of effectiveness is met. Regarding proportionality, the Litigation Chamber refers to the nature, severity, and duration of the violation, as well as other factors in Article 83.2 of the GDPR, as assessed in points III.1.1.2 to III.1.1.6 of this decision. The balancing of the aforementioned factors combined with consideration of the revenue of the first defendant leads the Litigation Chamber to conclude that the imposed fine meets the requirement of proportionality. Finally, in terms of deterrence, the fine encourages the first defendant to avoid any recurrence in the future, and the imposed fine has a deterrent effect on other data controllers.<sup>59</sup>

Therefore, the Litigation Chamber believes that the imposed fine of 45,000 euros meets the requirements of effectiveness, proportionality, and deterrent nature.

### III.1.1.9.

#### Other grievances

269. The Litigation Chamber proceeds with a dismissal regarding the other grievances and findings of the Inspection Service because, based on the facts and documents in the file, it cannot conclude that there are violations of the GDPR.

#### III.2. Regarding the second defendant

270. The Litigation Chamber proceeds with a dismissal regarding the grievances and findings of the Inspection Service concerning the second defendant because, based on the facts and documents in the file, it cannot conclude that there are violations of the GDPR.

#### IV. Publication of the decision

271. Given the importance of transparency regarding the decision-making process of the Litigation Chamber, this decision is published on the website of the Data Protection Authority. However, it is not necessary for this purpose that the identification data of the parties be directly communicated.

59 The deterrent effect must prevent both the first defendant and others from committing the same violation in the future, see European Data Protection Board (EDPB), Guidelines 04/2022 on the calculation of administrative fines under the GDPR (version 2.1), May 24, 2023, point 142.

Decision on the merits 114/2024 – 72/72

Judicial Code<sup>61</sup>, or via the e-Deposit computer system of Justice (Article 32ter of the Judicial Code).

(signed) Hielke HIJMANS

President of the Litigation Chamber

61 The request, accompanied by its annex, is sent, in as many copies as there are parties involved, by registered letter to the clerk of the court or filed with the registry.